0400. ○△×

TCP SYN Flooding 공격의 원리와 공격 발생 여부를 확인할 수 있는 희생자 서버의 상태 및 대응 방안에 관하여 서술하시오.

정답 및 해설

[TCP SYN Flooding 공격 원리]

- TCP 연결 설정 과정(3-Way Handshake)의 클라이언트를 인증하지 않는 구조적 취약점(요청한 클라이언트의 IP가 유효한지 검증하지 않는 취약점)을 이용한 공격
- 출발지 IP 주소를 위조한(IP 스푸핑) 다수의 SYN 패킷을 대상 시스템에 전송하여, 대상 시스템의 TCP 연결 자원(Backlog Queue)을 모두 소진시키는 서비스 거부 공격이다.

[희생자 서버 상태]

- 공격 발생 시 희생자 서버에서 netstat 명령을 통해 TCP 연결 상태를 보면, 다양한 출발지 IP의 클라이언트(위조된 IP)와 연결을 진행 중인 다수의 SYN_RECEIVED(SYN_RECV) 상태의 TCP 소켓을 확인할 수 있다.

```
[root@Fedora11 ~]# netstat -ant | grep SYN_RECV
Active Internet connections (servers and established)
Proto  Recv-Q  Send-Q   Local Address          Foreign Address          State
tcp        0       0   172.30.1.100:443       211.65.51.100:2274       SYN_RECV
tcp        0       0   172.30.1.100:443       51.0.14.36:2275          SYN_RECV
tcp        0       0   172.30.1.100:443       70.144.138.30:2326       SYN_RECV
tcp        0       0   172.30.1.100:443       25.25.234.203:2287       SYN_RECV
tcp        0       0   172.30.1.100:443       157.234.51.93:2297       SYN_RECV
tcp        0       0   172.30.1.100:443       191.138.123.220:2270     SYN_RECV
tcp        0       0   172.30.1.100:443       219.168.107.70:2283      SYN_RECV
tcp        0       0   172.30.1.100:443       251.24.242.177:2272      SYN_RECV
tcp        0       0   172.30.1.100:443       46.57.234.107:2264       SYN_RECV
tcp        0       0   172.30.1.100:443       167.229.36.173:2314      SYN_RECV
tcp        0       0   172.30.1.100:443       76.231.250.59:2281       SYN_RECV
tcp        0       0   172.30.1.100:443       206.155.57.86:2293       SYN_RECV
tcp        0       0   172.30.1.100:443       21.24.13.227:2268        SYN_RECV
tcp        0       0   172.30.1.100:443       173.158.232.17:2256      SYN_RECV
```

- (netstat 명령) 희생자 측 TCP 소켓 상태
- TCP SYN Flooding 공격 발생하면, 서버는 SYN/ACK 패킷을 전송했음에도 ACK 응답을 받지 못하므로 다수의 SYN_RECEIVED 상태 소켓(Half Open 상태)이 누적됨
- SYN_RECEIVED 상태 : SYN 요청에 대해 SYN/ACK를 응답한 뒤, 상대방의 ACK를 대기하는 상태
- Foreign Address 필드(원격 호스트 주소)를 통해 다수의 위조된 출발지 IP 확인

- 희생자 서버는 TCP 연결 자원(Backlog Queue)이 모두 소진되어 정상적인 서비스 요청을 받아들일 수 없는 상태가 된다.

[대응 방안]

1) TCP SYN Cookie 기능 활성화
   - TCP SYN Cookie 기능은 클라이언트의 유효성을 검증(클라이언트의 IP 주소 위조 여부 검증)하기 위한 기술로, 정상 클라이언트로 확인될 때까지 서버의 Backlog Queue에 연결 요청 정보를 저장하지 않는다. 따라서 Backlog Queue 자원 고갈을 노리는 TCP SYN Flooding 공격에 효과적으로 대응할 수 있다.
2) 임계치(Threshold) 기반 차단 정책 적용
   - 네트워크 보안장비(방화벽, IDS/IPS 등)에 출발지 또는 목적지 IP별 단위 시간당 SYN 패킷 발생량을 기준으로 임계치(Threshold)를 설정하고, 이를 초과하는 SYN 트래픽을 탐지하면 차단하도록 정책을 적용한다.
3) First SYN Drop 기능 활성화
   - 출발지 IP별로 최초로 수신되는(첫 번째) SYN 패킷을 의도적으로 폐기(Drop)하고, 동일 출발지에서 SYN 패킷이 재전송될 경우 이를 정상 요청으로 판단하여 허용하는 방식의 방어 기법이다.
   - 정상적인 TCP 클라이언트는 TCP 오류제어 메커니즘에 의해 SYN 패킷 재전송을 수행하지만, 악성 봇을 통한 공격은 정상적인 TCP 클라이언트가 아니기 때문에 재전송을 하지 않는 특성을 이용한 방어 기법이다.
4) Backlog Queue의 크기 확장
   - 운영체제(커널) 설정을 통해 Backlog Queue의 크기를 확장하면 더 많은 Half Open 연결 상태를 일시적으로 수용할 수 있어 TCP SYN Flooding 공격에 대한 임시적인 대응이 가능하다. 다만 이는 근본적인 해결책이 아니라 임시적인 보완 조치이므로 추가적인 방어 기법과 함께 적용하는 것이 일반적이다.

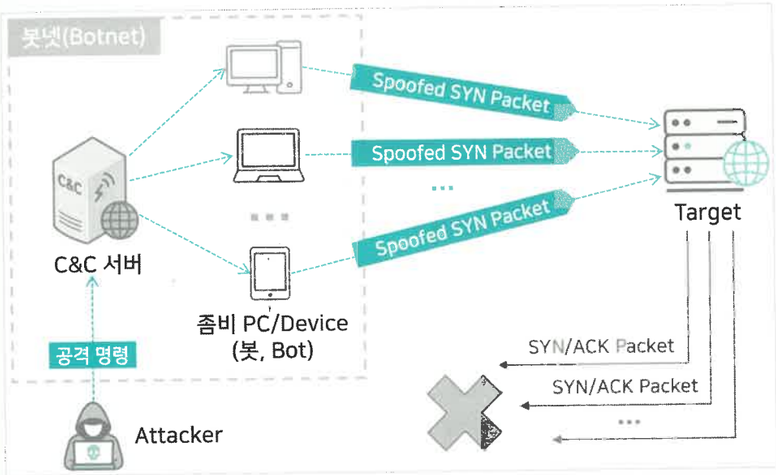
0401. ○△× 24.4회.산기

TCP SYN Flooding 공격은 외부로부터 TCP 연결 요청을 받을 수 없는 상태로 만드는 서비스 거부 공격 기법이다. 이와 관련하여 다음 질문에 답하시오.

1) TCP SYN Flooding 공격은 어떤 취약점을 이용한 공격인가?

2) TCP SYN Flooding 공격의 공격 원리에 관해 서술하시오.

정답 및 해설



1) TCP 연결 설정 과정(3-Way Handshake)의 구조적 취약점을 이용한 공격이다. TCP 연결 설정 과정에서 클라이언트를 인증하지 않는 구조적 취약점(요청한 클라이언트의 IP가 유효한지 검증하지 않는 취약점)을 이용하여 출발지 IP를 위조한 다수의 SYN 요청을 보내고 그 결과 서버에 과도한 Half Open 연결 상태가 지속된다. 이에 따라 TCP 연결 자원(Backlog Queue)이 고갈되어 정상적인 연결 요청을 처리할 수 없게 된다.

2) 출발지 IP 주소를 위조한 다수의 SYN 패킷을 대상 시스템에 전송하면, 대상 시스템은 SYN/ACK 패킷으로 응답한다. 하지만 출발지 IP 주소는 위조된 주소이므로 SYN/ACK 패킷에 대한 ACK 응답을 보내지 않기 때문에 대상 시스템은 다수의 Half Open 연결 상태가 일정 시간 유지되며 결국 TCP 연결 자원(Backlog Queue)을 모두 소진하게 된다. 따라서 정상 사용자의 TCP 연결 요청을 더 이상 처리할 수 없게 된다.

0402. ○△×

다음 비정상 트래픽 분석 결과를 참고하여 (A) 어떤 서비스 거부(DoS) 공격을 당하고 있으며, (B) 그 판단 이유가 무엇인지 상세하게 서술하시오.

정상 트래픽

HTTP 요청 메시지	HTTP 요청 메시지 패킷 바이트(16진수 표시)
GET /index.php HTTP/1.1 Host: 172.30.1.100 User-Agent: curl/7.87.0 Accept: */*	0040 40 05 47 45 54 20 2f 69 6e 64 65 78 2e 70 68 70 @ GET /i ndex.php 0050 20 48 54 54 50 2f 31 2e 31 0d 0a 48 6f 73 74 3a HTTP/1. 1 Host: 0060 20 31 37 32 2e 33 30 2e 31 2e 31 30 30 0d 0a 55 172.30. 1.100 U 0070 73 65 72 2d 41 67 65 6e 74 3a 20 63 75 72 6c 2f ser-Agen t: curl/ 0080 37 2e 38 37 2e 30 0d 0a 41 63 63 65 70 74 3a 20 7.87.0 Accept: 0090 2a 2f 2a 0d 0a 0d 0a */* ····

요청 헤더의 끝을 의미하는 개행(CRLF, 0x0D0A) 연속 2번 전송

비정상 트래픽

HTTP 요청 메시지	HTTP 요청 메시지 패킷 바이트(16진수 표시)
GET /index.php HTTP/1.1 Host: 172.30.1.100 User-Agent: Mozilla/5.0 Pragma: 26264 Pragma: 29082 Pragma: 18423	0000 00 0c 29 71 ab 96 00 0c 29 6e 24 25 08 00 45 00 ··)q····)n$%··E· 0010 00 37 62 b9 40 00 7f 06 df a9 0a 0a 01 d2 ac 1e ·7b·@····· ····· 0020 01 64 cb 55 00 50 04 39 8a 00 a2 32 7a 05 50 18 ·d·U·P·9 ···2z·P· 0030 fa f0 89 84 00 00 50 72 61 67 6d 61 3a 20 31 38 ····· Pr agma: 18 0040 34 32 33 0d 0a 423··

요청 헤더가 끝나지 않은 상태에서 의미 없는 헤더(Pragma)만 매우 느린 속도로 지속해서 전송

정답 및 해설

(A) 어떤 공격인가?

- Slow HTTP Header 공격(Slowloris 공격)을 당하고 있는 것으로 판단된다.

(B) 판단 이유는 무엇인가?

- Slow HTTP Header 공격(Slowloris 공격)은 다수의 HTTP 요청을 전송하면서 요청 헤더의 끝을 의미하는 개행 문자(CRLF) 연속 2번을 보내지 않고, 의미 없는 헤더만 매우 느린 속도로 지속적으로 전송하여 웹 서버와의 연결을 장시간 유지시키는 서비스 거부(DoS) 공격이다.
- 정상 트래픽은 요청 헤더 종료를 위해 개행 문자가 연속으로 두 번(CRLF CRLF) 전송되지만, 비정상 트래픽은 요청 헤더 종료(CRLF CRLF)가 전송되지 않은 상태에서 의미 없는 헤더(Pragma)만 매우 느린 속도로 지속해서 전송되고 있다. 이로 인해 웹 서버는 요청 헤더가 아직 끝나지 않은 것으로 판단하여 연결을 유지한 채 대기하게 된다. 따라서 Slow HTTP Header 공격으로 판단된다.

0403. ○△×

다음 비정상 트래픽 분석 결과를 참고하여 (A) 어떤 서비스 거부(DoS) 공격을 당하고 있으며, (B) 그 판단 이유가 무엇인지 상세하게 서술하시오.

정상 트래픽	비정상 트래픽
HTTP POST 요청 메시지	HTTP POST 요청 메시지
POST /board_write.php HTTP/1.1 Host: 172.30.1.100 User-Agent: Mozilla/5.0 Connection: keep-alive Content-Length: 6 Content-Type: application/x-www-form-urlencoded algisa	POST /board_write.php HTTP/1.1 Host: 172.30.1.100 User-Agent: Mozilla/5.0 Connection: keep-alive Content-Length: 1000000 Content-Type: application/x-www-form-urlencoded A
Content-Length가 6바이트이며, 요청 메시지 바디에 6바이트 데이터(algisa)를 담아 전송	Content-Length가 1,000,000바이트로 설정되어 있으나, 1바이트씩 데이터(A)를 매우 느린 속도로 지속해서 전송

정답 및 해설

(A) 어떤 공격인가?

- Slow HTTP POST 공격(RUDY 공격)을 당하고 있는 것으로 판단된다.

(B) 판단 이유는 무엇인가?

- Slow HTTP POST 공격(RUDY 공격)은 다수의 HTTP POST 요청을 전송하면서 Content-Length 헤더 값을 실제 전송할 데이터 크기보다 매우 크게 설정한 후, 매우 작은 데이터를 천천히 지속적으로 전송하여 웹 서버와의 연결을 장시간 유지시키는 서비스 거부(DoS) 공격이다.
- 정상 트래픽은 Content-Length 헤더 값만큼 데이터가 전송되지만, 비정상 트래픽은 Content-Length 헤더에 1,000,000바이트와 같이 비정상적으로 큰 값이 설정되어 있음에도 실제로는 1바이트씩 매우 느린 속도로 전송되고 있다. 이로 인해 웹 서버는 아직 수신해야 할 데이터가 남아 있다고 판단하여 연결을 유지한 채 대기하게 된다. 따라서 Slow HTTP POST 공격으로 판단된다.

0404. ○△×

다음 비정상 트래픽 분석 결과를 참고하여 (A) 어떤 서비스 거부(DoS) 공격을 당하고 있으며, (B) 그 판단 이유가 무엇인지 상세하게 서술하시오.

정상 트래픽

HTTP 서버(172.30.1.100)의 응답 패킷에 대한 클라이언트(10.10.1.200)의 ACK 응답(수신 확인 응답)

```
4783 64.179   172.30.1.100   10.10.1.200   TCP  80 → 56324 [ACK] Seq=1 Ack=376 Win=6912 Len=1448
4791 64.179   10.10.1.200   172.30.1.100   TCP  56324 → 80 [ACK] Seq=376 Ack=1449 Win=64128 Len=0

> Flags: 0x010 (ACK)
  Window: 501
  [Calculated window size: 64128]
```

클라이언트는 서버 응답 패킷에 대한 ACK 응답(Ack.Num=1449)을 전송하면서, TCP 헤더에 수신 버퍼의 여유 공간 크기(Window=64128)를 설정함

비정상 트래픽

HTTP 서버(172.30.1.100)의 응답 패킷에 대한 클라이언트(10.10.1.200)의 ACK 응답(수신 확인 응답)

```
7 0.021   172.30.1.100   10.10.1.200   TCP  80 → 36436 [PSH, ACK] Seq=577 Ack=333 Win=6912 Len=576
9 0.062   10.10.1.200   172.30.1.100   TCP  [TCP ZeroWindow] 36436 → 80 [ACK] Seq=333 Ack=1153 Win=0 Len=0

> Flags: 0x010 (ACK)
  Window: 0
  [Calculated window size: 0]
```

클라이언트는 서버 응답 패킷에 대한 ACK 응답(Ack.Num=1153)을 전송하면서, TCP 헤더에 수신 버퍼의 여유 공간 크기를 0(Window=0)으로 설정하여 이후 서버 응답 전송을 지연시킴

정답 및 해설

(A) 어떤 공격인가?

- Slow HTTP Read 공격을 당하고 있는 것으로 판단된다.

(B) 판단 이유는 무엇인가?

- Slow HTTP Read 공격은 다수의 HTTP 요청에 대한 웹 서버 응답 과정에서 클라이언트가 TCP 윈도우 크기(Window Size)를 0으로 설정한 Zero Window 패킷을 지속적으로 전송하여 HTTP 응답 데이터의 수신을 지연시키는 서비스 거부(DoS) 공격이다.
- 정상 트래픽은 TCP 윈도우 크기(Window Size)가 수신 버퍼의 여유 공간 크기만큼 설정되어 전송되지만, 비정상 트래픽은 TCP 윈도우 크기를 0으로 설정한 Zero Window 패킷이 지속적으로 웹 서버에 전송되고 있다. 이로 인해 웹 서버는 응답 데이터를 더 이상 전송하지 못한 채 대기하게 된다. 따라서 Slow HTTP Read 공격으로 판단된다.

0405. ○△×

DRDoS(Distributed Reflection Denial of Service) 공격의 (A) 공격 원리와 (B) 공격 유형 및 (C) 일반적인 DDoS(Distributed Denial of Service) 공격과의 차이점을 서술하시오.

정답 및 해설

(A) 공격 원리

- DRDoS 공격은 공격자가 출발지 IP 주소를 공격 대상 시스템의 IP 주소로 위조(IP 스푸핑)한 후, 다수의 증폭/반사 서버(Amplifier/Reflector)로 서비스 요청을 전송하여 공격 대상 시스템이 증폭된 대량의 응답 트래픽을 수신하도록 만드는 서비스 거부(DoS) 공격이다.

(B) (공격 유형) DRDoS 공격은 사용하는 프로토콜과 방식에 따라 다양한 형태로 나타날 수 있으며, 대표적인 유형은 다음과 같다.

- TCP 기반 증폭/반사 유형 : TCP 연결 설정 과정의 구조적 취약점을 이용한 방식으로, 출발지 IP 주소를 공격 대상 시스템의 IP 주소로 위조한 TCP SYN 패킷을 증폭/반사 서버(TCP 서버)로 전송하여, 해당 서버가 응답하는 SYN/ACK 패킷이 공격 대상 시스템으로 전달되도록 하는 유형
- UDP 기반 증폭/반사 유형 : 출발지 IP 주소를 공격 대상 시스템의 IP 주소로 위조한 서비스 요청 패킷을 다수의 UDP 기반 증폭/반사 서버로 전송하여, 해당 서버의 응답 패킷이 공격 대상 시스템으로 전달되도록 하는 유형
- ICMP 기반 증폭/반사 유형 : 출발지 IP 주소를 위조한 ICMP 요청 패킷을 증폭/반사 서버로 전송하여 ICMP 응답 패킷이 공격 대상 시스템으로 향하도록 하는 방식으로, 대표적인 공격으로 스머프(Smurf) 공격이 있다.

(C) 일반적인 DDoS 공격과의 차이점

- 일반적인 DDoS 공격은 공격 트래픽이 공격자(좀비 PC/Device)에서 직접 발생하는 반면, DRDoS 공격은 출발지 IP 주소를 공격 대상 시스템의 IP 주소로 위조(IP 스푸핑)한 후 다수의 증폭/반사 서버를 경유하여 공격이 이루어지므로 공격 근원지를 역추적하는 것이 DDoS 공격에 비해 훨씬 어렵다.
- DRDoS 공격은 요청 대비 응답이 큰 증폭 효과를 이용하므로, 동일한 공격 트래픽을 사용하는 일반적인 DDoS 공격보다 공격 효율이 높다.

0406. ○ △ × 21.2회.기사

다음은 DRDoS(Distributed Reflection Denial of Service) 공격에 관한 내용이다. 각각의 질문에 답하시오.

1) DRDoS의 공격 원리에 관하여 서술하시오.

2) DRDoS 공격과 일반적인 DoS(DDoS) 공격과의 차이점을 설명하시오.

3) 라우터에 적용할 수 있는 Unicast RPF(uRPF) 패킷 필터링 기법의 동작 원리를 설명하시오.

정답 및 해설

1) DRDoS 공격은 공격자가 출발지 IP 주소를 공격 대상 시스템의 IP 주소로 위조(IP 스푸핑)한 후, 다수의 증폭/반사 서버(Amplifier/Reflector)로 서비스 요청을 전송하여 공격 대상 시스템이 증폭된 대량의 응답 트래픽을 수신하도록 만드는 서비스 거부(DoS) 공격이다.

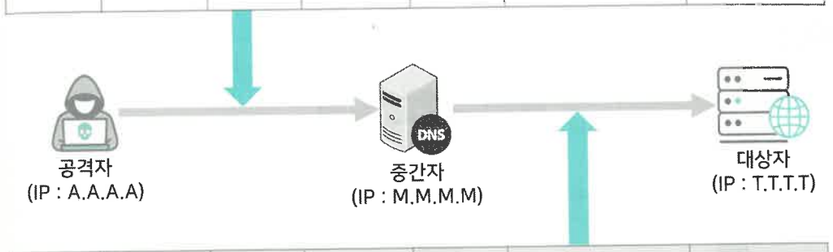
2) DRDoS 공격과 일반적인 DoS(DDoS) 공격의 차이점은 다음과 같다.
- 일반적인 DDoS 공격은 공격 트래픽이 공격자(좀비 PC/Device)에서 직접 발생하는 반면, DRDoS 공격은 출발지 IP 주소를 공격 대상 시스템의 IP 주소로 위조(IP 스푸핑)한 후 다수의 증폭/반사 서버를 경유하여 공격이 이루어지므로 공격 근원지를 역추적하는 것이 DDoS 공격에 비해 훨씬 어렵다.
- DRDoS 공격은 요청 대비 응답이 큰 증폭 효과를 이용하므로, 동일한 공격 트래픽을 사용하는 일반적인 DDoS 공격보다 공격 효율이 높다.

3) Unicast RPF(Reverse Path Forwarding) 패킷 필터링 기법은 내외부 경계 라우터에서 외부(인터넷)에서 내부 네트워크로 유입되는 패킷에 대해, 라우팅 테이블에 역경로(Reverse Path)가 존재하는지 검사하여 경로가 존재하지 않거나 비정상적인 인터페이스로 유입된 패킷을 차단하는 기법을 의미한다.
- 역경로(Reverse Path) 검사의 의미 : 유입된 패킷의 출발지 IP 주소를 역으로 목적지 IP 주소로 간주했을 때, 해당 주소로 패킷을 보낼 수 있는 라우팅 경로가 존재하는지, 또는 패킷이 유입된 인터페이스를 통해 다시 전송 가능한지를 확인하는 것을 의미한다.
- 차단 원리 : 출발지 IP 주소가 위조된 비정상 패킷은 라우팅 테이블에 역경로가 존재하지 않거나(예: 사설 IP 주소 등), 실제 경로와 패킷이 유입된 인터페이스가 일치하지 않으므로(예: 위조된 공인 IP 주소 등) 차단된다.

0407. ○ △ × 18.2회.산기

다음은 디도스(DDoS) 공격 과정에 관한 내용이다. 각각의 질문에 답하시오.

SRC_IP	SRC_PORT	DST_IP	DST_PORT	Protocol	Info	IP Packet size
T.T.T.T	2417	M.M.M.M	53	UDP	Standard Query TXT algisa.com	56byte



SRC_IP	SRC_PORT	DST_IP	DST_PORT	Protocol	Info	IP Packet size
M.M.M.M	53	T.T.T.T	2417	IP	Stand Query Response TXT TXT TXT···	1,500byte
M.M.M.M	53	T.T.T.T	2417	IP		1,500byte
M.M.M.M	53	T.T.T.T	2417	IP		54byte

1) 위와 같이 공격자와 대상자 사이에 중간 호스트가 존재하여 이루어지는 디도스(DDoS) 공격의 이름은 무엇인가?

2) 다음은 공격자, 중간자, 대상자 사이에 공격이 이루어지는 절차에 대한 설명이다. 빈칸( )에 적절한 설명을 쓰시오.

① (A)

② 중간자는 다수의 DNS 질의에 대한 응답을 위조된 출발지 IP인 대상자에 응답한다.

③ (B)

3) 중간자의 응답 데이터 패킷이 1,500byte, 1,500byte, 54byte로 분할되어 대상자로 전달되는 이유는 무엇인지 서술하시오.

정답 및 해설

1) 공격자가 출발지 IP 주소를 대상자의 IP 주소로 위조(IP 스푸핑)하여 DNS 질의(53/UDP)를 수행하고, DNS 질의 유형을 TXT 타입으로 설정하여 응답 트래픽을 증폭시켜 대상자에게 전송하는 것으로 보아 DNS 증폭 DRDoS 공격으로 판단된다.

2) 공격 절차는 다음과 같다.
- (A) 공격자는 증폭된 DNS 응답이 대상자 서버로 대량 전달되도록 출발지 IP 주소를 대상자 IP 주소로 위조한 TXT 타입의 DNS 질의를 중간자에게 다수 전송한다.
- (B) 대상자는 요청하지 않은 대량의 DNS 응답을 중간자로부터 수신하게 되어 서비스 거부 상태가 된다.

3) IP 패킷은 하위 물리적 네트워크 프로토콜(예: Ethernet)의 MTU(Maximum Transmission Unit) 크기에 따라 단편화가 발생한다. 위의 경우 응답 데이터의 크기가 Ethernet MTU인 1,500byte를 초과하여, 하나의 IP 데이터그램이 1,500 byte, 1,500 byte, 54 byte의 3개 단편으로 분할되어 전송된 것으로 판단된다.

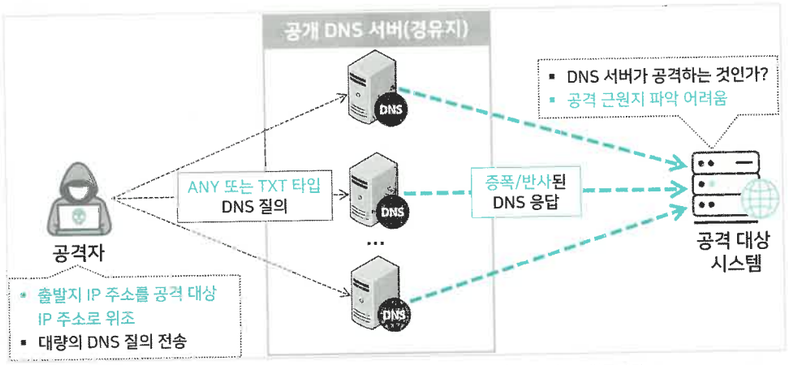
0408. ○△× 15.2회.기사

디도스(DDoS) 공격 유형 중 DNS 증폭 공격(Amplification Attack)에 대한 특징을 아래의 항목에 따라 서술하시오.

(1) 주로 사용되는 IP 기반 공격과 (2) 해당 공격 기법을 이용하는 이유

(3) 주로 사용하는 DNS 질의 타입과 (4) 해당 타입을 사용하는 이유

정답 및 해설



1) IP 스푸핑(Spoofing) 공격을 통해 출발지 IP 주소를 공격 대상 시스템의 IP 주소로 위조한다.
2) DNS 질의(요청)에 대한 응답이 공격 대상 시스템으로 전달되도록 하고 공격의 근원지(공격자)를 역추적하기 어렵게 하기 위함이다.
3) ANY 타입 또는 TXT 타입
4) DNS 질의(요청) 대비 DNS 응답이 매우 크기 때문에 증폭 공격을 효과적으로 할 수 있다.

0409. ○△× 23.1회.기사

디도스(DDoS) 공격 유형 중 DNS 증폭 공격(Amplification Attack)에 주로 사용되는 IP 기반 공격 기법과 해당 공격 기법을 사용하는 이유를 서술하시오.

정답 및 해설

1) (IP 기반 공격 기법) IP 스푸핑 공격을 통해 출발지 IP 주소를 공격 대상 시스템의 IP 주소로 위조한다.
2) (이유) DNS 질의(요청)에 대한 응답이 공격 대상 시스템으로 전달되도록 하고 공격의 근원지(공격자)를 역추적하기 어렵게 하기 위함이다.

관련지식

[TCP/IP 커널 파라미터 보안 설정]

1) 개요

① sysctl 명령은 리눅스 커널 파라미터를 확인하거나 설정할 때 사용하는 명령어이며, 사용 방법은 다음과 같다.
- 파라미터 확인: sysctl -n 〈parameter〉 명령을 통해 특정 파라미터를 확인하거나, sysctl -a 명령을 통해 현재 모든 커널 파라미터를 확인할 수 있다.
- 파라미터 설정 : sysctl -w 〈parameter〉=〈value〉

② ndd 명령은 유닉스(솔라리스)의 네트워크 관련 커널 파라미터를 확인하거나 설정할 때 사용하는 명령어이며, 사용 방법은 다음과 같다.
- 파라미터 확인 : ndd /dev/〈driver〉 〈parameter〉
- 파라미터 설정 : ndd -set /dev/〈driver〉 〈parameter〉 〈value〉
- TCP/IP 커널의 경우 〈driver〉는 ARP, IP, TCP, UDP가 해당한다.

2) Smurf(스머프) 공격 대응 설정 17.1회.기사

(가) 개요

① Smurf(스머프) 공격은 출발지 IP를 희생자(Target) IP로 위조(IP 스푸핑)한 후 증폭/반사 네트워크의 다이렉티드 브로드캐스트(Directed Broadcast) 주소로 ICMP Echo Request 패킷을 전송함으로써, 해당 네트워크의 모든 호스트가 ICMP Echo Reply 패킷을 희생자에게 보내도록 만들어 네트워크 대역폭을 소진시키는 서비스 거부 공격이다.

(나) 공격 대응 방안(증폭/반사 네트워크 관점)

① 증폭/반사 네트워크로 악용되는 것을 방지하기 위해, 외부에서 유입되는 다이렉티드 브로드캐스트 패킷을 라우터(네트워크 장비)에서 차단한다.

② 시스템이 증폭/반사 역할을 하지 않도록, 다이렉티드 브로드캐스트로 수신되는 ICMP Echo Request 패킷에 대해 응답하지 않도록 설정한다.

(다) 리눅스 시스템 설정

```
File  Edit  View  Terminal  Help
[root@Fedora11 ~]# sysctl -a | grep net.ipv4.icmp_echo_ignore_broadcasts
net.ipv4.icmp_echo_ignore_broadcasts = 0
[root@Fedora11 ~]#
[root@Fedora11 ~]# sysctl -w net.ipv4.icmp_echo_ignore_broadcasts=1
net.ipv4.icmp_echo_ignore_broadcasts = 1
[root@Fedora11 ~]#
[root@Fedora11 ~]#
```

① sysctl -w net.ipv4.icmp_echo_ignore_broadcasts=1 : 브로드캐스트 주소로 전송된 ICMP Echo Request 메시지 수신 시 이를 무시한다.(1은 true를 의미)

(라) 유닉스(Solaris) 시스템 설정

```
터미널                                                    터미널
bash-3.2# ndd -set /dev/ip ip_respond_to_echo_broadcast 0
bash-3.2#
bash-3.2# ndd -set /dev/ip ip_forward_directed_broadcasts 0
bash-3.2#
bash-3.2# ndd /dev/ip ip_respond_to_echo_broadcast
0
bash-3.2# ndd /dev/ip ip_forward_directed_broadcasts
0
```

① ndd -set /dev/ip ip_respond_to_echo_broadcast 0 : 브로드캐스트 주소로 전송된 ICMP Echo Request 메시지 수신 시 응답하지 않는다.(0은 false를 의미).

② ndd -set /dev/ip ip_forward_directed_broadcasts 0 : directed broadcast IP 패킷을 포워딩하지 않는다.(0은 false를 의미)

3) TCP SYN Flooding 공격 대응 설정 17.1회.기사

(가) 개요

① TCP SYN Flooding 공격은 출발지 IP 주소를 위조한(IP 스푸핑) 다수의 SYN 패킷을 대상 시스템에 전송하여, 대상 시스템의 TCP 연결 자원(Backlog Queue)을 모두 소진시키는 서비스 거부 공격이다.

(나) 공격 대응 방안

① (TCP SYN Cookie 기능 활성화) TCP SYN Cookie 기능은 클라이언트의 유효성을 검증(클라이언트의 IP 주소 위조 여부 검증)하기 위한 기술로, 정상 클라이언트로 확인될 때까지 서버의 Backlog Queue에 연결 요청 정보를 저장하지 않는다. 따라서 Backlog Queue 자원 고갈을 노리는 TCP SYN Flooding 공격에 효과적으로 대응할 수 있다.

② (임계치(Threshold) 기반 차단 정책 적용) 네트워크 보안장비(방화벽, IDS/IPS 등)에 출발지 또는 목적지 IP별 단위 시간당 SYN 패킷 발생량을 기준으로 임계치(Threshold)를 설정하고, 이를 초과하는 SYN 트래픽을 탐지하면 차단하도록 정책을 적용한다.

③ (First SYN Drop 기능 활성화) 출발지 IP별로 최초로 수신되는(첫 번째) SYN 패킷을 의도적으로 폐기(Drop)하고, 동일 출발지에서 SYN 패킷이 재전송될 경우 이를 정상 요청으로 판단하여 허용하는 방식의 방어 기법이다.

④ (Backlog Queue 크기 확장) 운영체제(커널) 설정을 통해 Backlog Queue의 크기를 확장하면 더 많은 Half Open 연결 상태를 일시적으로 수용할 수 있어 TCP SYN Flooding 공격에 대한 임시적인 대응이 가능하다.

(다) 리눅스 시스템 설정

```
File  Edit  View  Terminal  Help
[root@Fedora11 ~]# sysctl -a | grep net.ipv4.tcp_max_syn_backlog
net.ipv4.tcp_max_syn_backlog = 512
[root@Fedora11 ~]# sysctl -a | grep net.ipv4.tcp_syncookies
net.ipv4.tcp_syncookies = 0
[root@Fedora11 ~]#
[root@Fedora11 ~]# sysctl -w net.ipv4.tcp_max_syn_backlog=1024
net.ipv4.tcp_max_syn_backlog = 1024
[root@Fedora11 ~]# sysctl -w net.ipv4.tcp_syncookies=1
net.ipv4.tcp_syncookies = 1
[root@Fedora11 ~]#
```

① sysctl -w net.ipv4.tcp_max_syn_backlog=1024 : TCP Backlog Queue의 크기를 늘린다.

② sysctl -w net.ipv4.tcp_syncookies=1 : TCP SYN Cookie 기능을 활성화한다.(1은 true를 의미)

(라) 유닉스(Solaris) 시스템 설정

```
터미널                                                    터미널
bash-3.2# ndd -set /dev/tcp tcp_conn_req_max_q0 1024
bash-3.2#
bash-3.2# ndd /dev/tcp tcp_conn_req_max_q0
1024
bash-3.2#
```

① ndd -set /dev/tcp tcp_conn_req_max_q0 1024 : TCP Backlog Queue의 크기를 늘린다.

4) ICMP Redirect 공격 대응 설정

(가) 개요

① ICMP Redirect 공격은 공격자가 특정 IP 또는 IP 대역으로 나가는 패킷의 라우팅 경로를 자신에게 라우팅되도록 위조한 ICMP Redirection 메시지(Type 5)를 희생자 호스트에 전송하여 희생자 호스트의 라우팅 경로 정보(라우팅 테이블 정보)를 조작함으로써 패킷을 스니핑하는 기법이다.

(나) 공격 대응 방안

① ICMP Redirection 메시지 수신 시 이를 무시하고, ICMP Redirection 메시지를 전송하지 않도록 시스템(커널 파라미터) 설정을 한다.

(다) 리눅스 시스템 설정

```
File  Edit  View  Terminal  Help
[root@Fedora11 ~]# sysctl -a | grep net.ipv4.conf.all.accept_redirects
net.ipv4.conf.all.accept_redirects = 1
[root@Fedora11 ~]# sysctl -a | grep net.ipv4.conf.default.send_redirects
net.ipv4.conf.default.send_redirects = 1
[root@Fedora11 ~]#
[root@Fedora11 ~]# sysctl -w net.ipv4.conf.all.accept_redirects=0
net.ipv4.conf.all.accept_redirects = 0
[root@Fedora11 ~]# sysctl -w net.ipv4.conf.default.send_redirects=0
net.ipv4.conf.default.send_redirects = 0
[root@Fedora11 ~]#
```

① sysctl -w net.ipv4.conf.all.accept_redirects=0 : ICMP Redirect 메시지 수신 시 라우팅 테이블 변경을 허용하지 않는다.(0은 false를 의미)

② sysctl -w net.ipv4.conf.default.send_redirects=0 : ICMP Redirect 메시지를 전송하지 않는다.(0은 false를 의미)

(라) 유닉스(Solaris) 시스템 설정

```
터미널                                                    터미널
bash-3.2# ndd -set /dev/ip ip_ignore_redirect 1
bash-3.2# ndd -set /dev/ip ip_send_redirects 0
bash-3.2#
bash-3.2# ndd /dev/ip ip_ignore_redirect
1
bash-3.2# ndd /dev/ip ip_send_redirects
0
bash-3.2#
```

① ndd –set /dev/ip ip_ignore_redirect 1 : ICMP Redirection 메시지 수신 시 라우팅 테이블을 변경하지 않고 무시한다(1은 true를 의미).

② ndd –set /dev/ip ip_send_redirects 0 : ICMP Redirection 메시지를 전송하지 않는다(0은 false를 의미).

5) IP Source Routing(소스 라우팅) 기능 비활성화

(가) 개요

① IP Source Routing 기능은 IP 옵션 헤더를 이용하여 호스트나 라우터에 설정된 라우팅 경로를 이용하지 않고 출발지에서 직접 경로를 지정하는 방식으로 외부에서 직접 접근이 불가능한 내부 시스템에 우회하여 접근할 수 있는 보안상 문제점이 있다.

(나) 공격 대응 방안

① IP Source Routing 기능을 이용하는 IP 패킷 수신 시 이를 허용하지 않도록 시스템(커널 파라미터) 설정을 한다.

(다) 리눅스 시스템 설정

```
File  Edit  View  Terminal  Help
[root@Fedora11 ~]# sysctl -a | grep net.ipv4.conf.all.accept_source_route
net.ipv4.conf.all.accept_source_route = 1
[root@Fedora11 ~]# sysctl -w net.ipv4.conf.all.accept_source_route=0
net.ipv4.conf.all.accept_source_route = 0
[root@Fedora11 ~]#
```

① sysctl –w net.ipv4.conf.all.accept_source_route=0 : 소스 라우팅 IP 패킷 수신 시 이를 허용하지 않는다(0은 false를 의미).

(라) 유닉스(Solaris) 시스템 설정

```
터미널                                                    터미널
bash-3.2# ndd -set /dev/ip ip_forward_src_routed 0
bash-3.2#
bash-3.2# ndd /dev/ip ip_forward_src_routed
0
bash-3.2#
```

① ndd –set /dev/ip ip_forward_src_routed 0 : 소스 라우팅 IP 패킷 수신 시 이를 포워딩하지 않는다(0은 false를 의미).

6) IP Forward(포워드) 기능 비활성화 설정

(가) 개요

① IP Forward 기능은 호스트가 라우터처럼 동작하여 자신이 목적지가 아닌 IP 패킷에 대해 라우팅 테이블을 참조하여 해당 목적지로 전송해 주는 기능을 말한다.

② IP Forward 기능이 설정되어 있으면 이를 악용하여 다른 서버로 패킷 전송이 가능하므로 라우터 역할을 하는 서버가 아니라면 IP Forwarding 기능을 비활성화하도록 설정한다.

(나) 리눅스 시스템 설정

```
File  Edit  View  Terminal  Help
[root@Fedora11 ~]# sysctl -a | grep net.ipv4.ip_forward
net.ipv4.ip_forward = 1
[root@Fedora11 ~]# sysctl -w net.ipv4.ip_forward=0
net.ipv4.ip_forward = 0
[root@Fedora11 ~]#
```

① sysctl –w net.ipv4.ip_forward=0 : IP 포워드 기능을 비활성화한다.
(0은 false를 의미)

(다) 유닉스(솔라리스) 시스템 설정

```
터미널                                                    터미널
bash-3.2# ndd -set /dev/ip ip_forwarding 0
bash-3.2#
bash-3.2# ndd /dev/ip ip_forwarding
0
bash-3.2#
```

① ndd –set /dev/ip ip_forwarding 0 : IP 포워드 기능을 비활성화한다.
(0은 false를 의미)

0410. ○△× 17.1회.기사

다음은 유닉스(솔라리스) 커널 보안 설정에 관한 문제이다. 커널 컴파일 용도로 활용하는 아래 ndd 명령어와 관련된 공격 명칭과 명령의 의미를 쓰시오.

보기

(1) ndd –set /dev/ip ip_forward_directed_broadcasts 0

(2) ndd –set /dev/tcp tcp_conn_req_max_q0 1024

정답 및 해설

ndd 명령은 유닉스(솔라리스)에서 네트워크 관련 커널 파라미터를 관리하기 위한 명령이다. 보기의 커널 파라미터 설정과 관련하여 공격 명칭과 명령의 의미는 다음과 같다.

1) 스머프(Smurf) 공격에 대응하기 위한 커널 파라미터 설정으로 Directed Broadcast IP 패킷을 포워딩하지 않도록 설정한다.
2) TCP SYN Flooding 공격에 대응하기 위한 커널 파라미터 설정으로 TCP Backlog Queue(연결요청대기큐)의 크기를 1024로 설정한다.

0411. ○△× 17.1회.산기

무선랜 보안 문제는 무선랜이 보급된 이래로 지속해서 반복되고 있는 문제이다. 무선랜에 대한 보안은 무선랜을 구성하고 있는 구성요소, 무선랜의 사용 주체, 무선랜의 사용 용도에 따라 다양한 관점에서 고려되어야 한다. 안전한 무선랜 구축을 위해 무선 AP(Access Point)에 적용할 보안 설정을 4가지 이상 서술하시오.

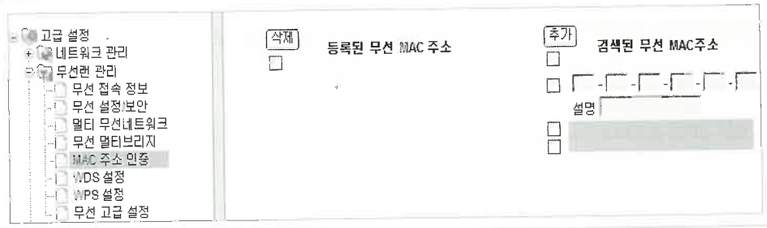
정답 및 해설

1) 무선 AP의 도난 및 공격자의 접근으로부터 보호할 수 있도록 보호 케이스 설치, AP 리셋 버튼 차단 등 물리적 보안대책을 확보한다.
2) 상 무선 AP 관리자 모드 접속 비밀번호를 설정하고 주기적으로 변경하여 공격자가 AP 관리자 모드로 접속하는 것을 방지한다.
3) SSID(Service Set Identifier)를 초기 설정값이 아닌 새로운 값으로 변경하여 공격자가 쉽게 인지하지 못하도록 한다.
4) SSID(Service Set Identifier)를 브로드캐스트(broadcast)하지 않고 숨김 모드로 설정하여 공격자에게 노출되는 것을 최소화한다.
5) 공격자의 접속 방지 및 무선 구간에서의 데이터 기밀성과 무결성을 유지하기 위해 무선 AP에서 제공하는 안전한 인증 및 암호화 방식을 적용한다.
6) 무선 AP에 접속을 허용할 무선 단말기 리스트를 등록하여(MAC 필터링) 임의 사용자 접근을 차단한다.

0412. ○△× 14.1회.기사

다음은 무선랜 보안 기능 중 MAC 기반 필터링 설정 부분이다. 다음 각각의 질문에 답하시오.

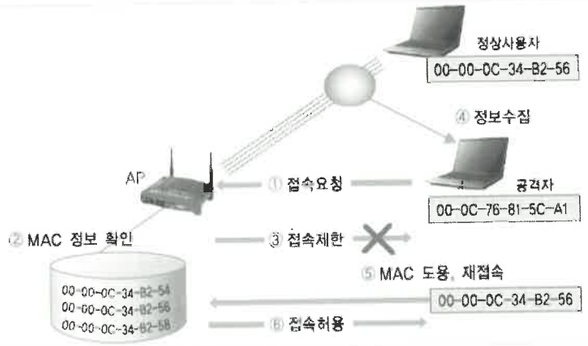
보기



1) MAC 주소를 구성하는 48비트 주소는 크게 두 부분으로 구성된다. 이를 설명하시오.
2) 무선랜에서 사용하는 MAC Address Filtering 보안 기법에 관해 설명하고 장단점을 각각 기술하시오.
3) MAC Address Filtering 보안 기능을 우회하는 해킹 기법을 구체적으로 기술하시오.

정답 및 해설

1) 상위 24비트는 제조사(벤더) 식별자로 사용되고, 하위 24비트는 해당 제조사(벤더)에서 부여한 일련번호로 사용된다. 따라서 이 둘을 합하여 고유한 식별 주소가 된다.
2) MAC 주소 필터링은 무선랜 접속을 허용할 단말의 MAC 주소를 무선 AP에 사전 등록하여 등록된 단말에 대해서만 접속을 허용해주는 인증방식을 말한다. 접근 제어 방식이 간단하고 기본적인 공격을 효과적으로 방어할 수 있는 인증 기술로 많은 종류의 무선 AP에서 지원하는 기법이지만 공격자가 정상 단말의 MAC 주소로 위조함으로써 쉽게 무력화될 수 있다.
3) 먼저 공격자는 자신의 접속 요청이 제한되고 있음을 확인한 후 정상 사용자와 무선 AP 사이의 트래픽을 분석하여 정상 사용자의 MAC 주소를 알아낸다. 정상 사용자의 MAC 주소를 확인한 공격자는 자신의 MAC 주소를 정상 사용자의 MAC 주소로 위조하여 접속을 재요청하게 되고 이 경우 AP는 정상 사용자의 접속 요청으로 여기고 접속을 허용하게 된다.



〈MAC Filtering / KISA 무선랜 보안안내서〉

0413. ○ △ × 13,2회.산기 22,1회.산기

최근 인터넷 모바일 환경이 확산하면서 공개용 무선 LAN 사용이 증가함에 따라, 공격자의 보안이 취약한 무선 LAN을 이용한 다양한 해킹 사고가 발생하고 있다. 이를 예방하는 방안으로 무선 데이터 암호화 방식을 많이 사용하고 있으며 그 중 대표적인 암호화 방식인 WEP 방식을 사용하고 있으나 취약하여 권고하고 있지 않다. WEP 암호 방식의 문제점을 모두 기술하시오.

정답 및 해설

1) 짧은 길이의 초기벡터(IV:Initialize Vector) 값의 사용으로 인해 IV 값이 재사용될 가능성이 높다.
2) 불완전한 RC4 암호 알고리즘 사용으로 인한 암호키 노출 가능성이 높다.
3) 짧은 길이의 암호키 사용으로 인한 공격 가능성이 높다.
4) 암호키 노출로 인한 무선 전송 데이터의 노출 위험성이 높다.

0414. ○ △ × 14,2회.기사

다음 보기의 내용을 읽고 물음에 답하시오.

보기

VPN(Virtual Private Network)은 공중망을 이용하여 논리적으로 분리된 보안 채널(Secure Channel)을 구성함으로써 전송 데이터에 대한 기밀성, 무결성 등의 보안 서비스를 제공하는 기술이다.
VPN 구현을 위해 OSI 계층 기준으로 ① 2계층 및 3계층 터널링 프로토콜이 사용되며, 이 중 3계층 터널링 프로토콜은 보안 채널 구성 방식에 따라 ② 2가지 동작 모드를 가진다.

1) ①의 2계층에서 동작하는 VPN 터널링 프로토콜 3가지를 쓰시오.
2) ①의 3계층에서 동작하는 VPN 터널링 프로토콜을 쓰시오.
3) ②의 2가지 동작 모드를 기술하고, 각 모드별 보호(연결) 구간과 패킷의 보호 범위를 기술하시오.

정답 및 해설

1) PPTP, L2F, L2TP
2) IPsec
3) IPsec의 동작 모드에는 전송 모드(Transport Mode)와 터널 모드(Tunnel Mode)가 있다.
가) 전송 모드(Transport Mode)
- (보호 범위) IP 패킷의 페이로드(Payload)를 보호하는 동작 모드로, IP 프로토콜의 상위 프로토콜 데이터(예: TCP, UDP 데이터)를 보호한다.
- (보호 구간) 일반적으로 종단 노드(End Node, 종단 호스트) 간 IP 패킷 보호를 위해 사용한다.

나) 터널 모드(Tunnel Mode)
- (보호 범위) IP 패킷 전체를 보호하는 동작 모드이다.
- (보호 구간) 일반적으로 터널 게이트웨이 간 또는 종단 노드와 터널 게이트웨이 간 IP 패킷 보호를 위해 사용한다.

0415. ○ △ × 25,1회.기사

IPsec 보안 프로토콜의 정의와 2가지 동작 모드를 설명하시오.

정답 및 해설

1) (정의) IPsec은 종단 노드 간(End-to-End, Host-to-Host) 또는 터널(VPN) 게이트웨이 간 IP 패킷에 대한 기밀성, 무결성, 인증 등의 보안 서비스를 제공하는 네트워크 계층(IP 계층) 보안 프로토콜이다.
2) (동작 모드)
- 전송 모드(Transport Mode) : IP 패킷의 페이로드(Payload)를 보호하는 동작 모드로, 일반적으로 종단 노드(End Node, 종단 호스트) 간 IP 패킷 보호를 위해 사용한다.
- 터널 모드(Tunnel Mode) : IP 패킷 전체를 보호하는 동작 모드로, 일반적으로 터널 게이트웨이 간 또는 종단 노드와 터널 게이트웨이 간 IP 패킷 보호를 위해 사용한다.

0416. ○ △ × 23,2회.산기

IPsec 보안 프로토콜의 세부 프로토콜 2가지와 각 프로토콜이 제공하는 모든 보안 서비스를 서술하시오.

정답 및 해설

1) AH(Authentication Header) 프로토콜
- 메시지 인증 코드(MAC)를 이용하여 비연결형 무결성(Connectionless Integrity)과 데이터 원천 인증(Data Origin Authentication)을 보장한다.
- 순서번호(Sequence Number)를 이용하여 재전송(Replay, 재현) 공격을 방지한다.
- 기밀성(Confidentiality, 암호화)은 제공하지 않는다.

2) ESP(Encapsulating Security Payload) 프로토콜
- 메시지 인증 코드(MAC)를 이용하여 비연결형 무결성(Connectionless Integrity)과 데이터 원천 인증(Data Origin Authentication)을 보장한다.
- 대칭키 암호를 이용하여 기밀성(Confidentiality, 암호화)을 보장한다.
- 순서번호(Sequence Number)를 이용하여 재전송(Replay, 재현) 공격을 방지한다.

0417. ○ △ × 16,2회.산기

다음은 IPsec 보안 프로토콜에 관한 내용이다. 각 질문에 대해 답하시오.

1) 네트워크 구성 방식에 따른 두 가지 동작 모드를 설명하시오.
2) AH 프로토콜 사용 시 두 가지 동작 모드의 차이점을 IP 헤더와 연관하여 설명하시오.

정답 및 해설

1) 네트워크 구성 방식에 따른 IPsec 동작 모드
- 전송 모드(Transport Mode) : IP 패킷의 페이로드(Payload)를 보호하는 동작 모드로, 일반적으로 종단 노드(End Node, 종단 호스트) 간 IP 패킷 보호를 위해 사용한다.
- 터널 모드(Tunnel Mode) : IP 패킷 전체를 보호하는 동작 모드로, 일반적으로 터널 게이트웨이 간 또는 종단 노드와 터널 게이트웨이 간 IP 패킷 보호를 위해 사용한다.

2) AH 프로토콜의 전송 모드 사용 시 IP 헤더의 변경 가능한 필드(예: TTL 필드, Header Checksum 필드, 출발지 IP 필드 등)를 제외한 IP 패킷 전체를 인증하고, 터널 모드 사용 시 New IP 헤더의 변경 가능한 필드를 제외한 IP 패킷 전체를 인증한다.

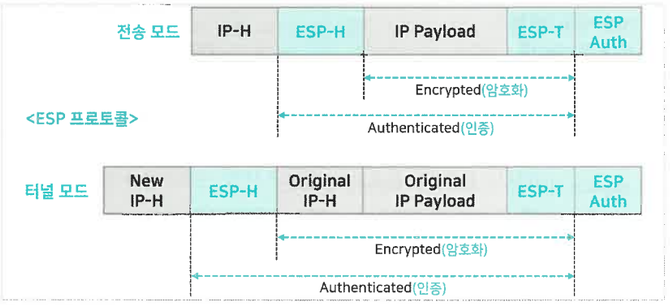
0418. ○△× 19.1회.기사

다음은 IPsec 보안 프로토콜에 관한 내용이다. AH, ESP 프로토콜의 전송 모드(Transport Mode)와 터널 모드(Tunnel Mode)에서 인증 구간과 암호화 구간에 관해 설명하고 키 교환 프로토콜을 쓰시오.

1) AH 프로토콜 전송 모드　　2) AH 프로토콜 터널 모드
3) ESP 프로토콜 전송 모드　　4) ESP 프로토콜 터널 모드　　5) 키 교환 프로토콜

정답 및 해설

1) (AH 프로토콜 전송 모드) IP 헤더의 변경 가능한 필드(예: TTL 필드, Header Checksum 필드, 출발지 IP 필드 등)를 제외한 IP 패킷 전체를 인증하며, 암호화(기밀성)는 제공하지 않는다.
2) (AH 프로토콜 터널 모드) New IP 헤더의 변경 가능한 필드(예: TTL 필드, Header Checksum 필드, 출발지 IP 필드 등)를 제외한 IP 패킷 전체를 인증하며, 암호화(기밀성)는 제공하지 않는다.



3) (ESP 프로토콜 전송 모드) IP 페이로드와 ESP 트레일러를 암호화한 후, 암호화된 데이터 전체와 ESP 헤더를 인증한다.
4) (ESP 프로토콜 터널 모드) 원본 IP 패킷 전체와 ESP 트레일러를 암호화한 후, 암호화된 데이터 전체와 ESP 헤더를 인증한다.

5) (키 교환 프로토콜) IKE(Internet Key Exchange) 프로토콜

0419. ○△× 20.1회.기사

다음 패킷을 IPsec의 ESP 프로토콜을 이용하여 터널 모드(Tunnel Mode)로 전송할 때 다음 각각의 질문에 답하시오.

IP Header	TCP Header	DATA

1) ESP 터널 모드로 전송할 때 추가되는 필드를 그림으로 도식화하시오.
2) 암호화(Encryption)가 적용되는 필드의 범위를 설명하시오.
3) 인증(Authentication)이 적용되는 필드의 범위를 설명하시오.

정답 및 해설

1) ESP 터널 모드 전송 시 아래와 같이 New IP 헤더(Header), ESP 헤더(Header), ESP 트레일러(Trailer), ESP 인증 데이터(Auth) 필드가 추가된다.

New IP Header	ESP Header	IP Header	TCP Header	DATA	ESP Trailer	ESP Auth

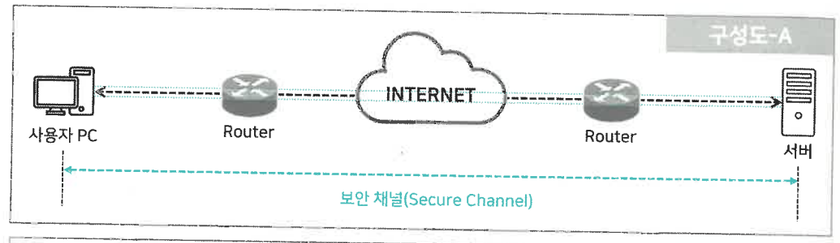
2) (암호화 적용 필드) ESP 터널 모드(Tunnel Mode) 암호화 시 원본 IP 패킷 전체와 ESP 트레일러를 암호화한다. 따라서 IP Header, TCP Header, DATA, ESP Trailer 필드가 암호화된다.
3) (인증 적용 필드) ESP 터널 모드(Tunnel Mode) 인증 시 암호화된 데이터 전체와 ESP 헤더를 인증한다. 따라서 ESP Header, IP Header, TCP Header, DATA, ESP Trailer 필드가 인증된다.

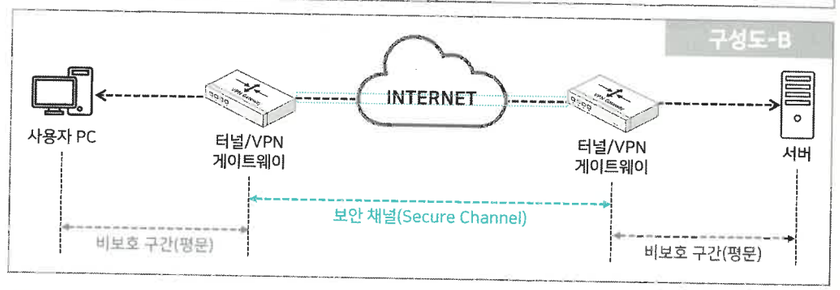
0420. ○ △ × 16,2회,기사

IPsec은 인터넷에서 IP 패킷을 더욱 안전하게 전송하기 위해 사용하는 보안 프로토콜로서 네트워크의 구성 방식에 따라 두 가지의 동작 모드(Operation Mode)를 사용하고 있다. 다음 질문에 각각 답하시오.

1) IPsec의 두 가지 동작 모드는 무엇이며 어떠한 차이점이 있는가?
(단, ESP를 사용한 패킷 암호화 기능으로 설명하시오)

2) 다음 네트워크 구성도를 보고 (1)에서 답한 동작 모드와 아래 연결 방식 간에 가장 적절한 방식을 각각 짝짓고 그 이유를 설명하시오.





정답 및 해설

1) IPsec은 전송 모드(Transport Mode)와 터널 모드(Tunnel Mode) 두 가지 방식으로 동작한다. ESP를 사용하는 경우, 전송 모드에서는 IP 페이로드와 ESP 트레일러(Trailer)를 암호화하고, 터널 모드에서는 원본 IP 패킷 전체와 ESP 트레일러(Trailer)를 암호화한다.

2) 구성도별 적절한 동작 모드와 그 이유는 다음과 같다.
- (구성도-A) 사용자 PC와 서버 간 종단(End-to-End) 구간에 보안 채널을 형성하고 있으므로, 종단 구간에 보안 서비스를 제공해 주는 전송 모드(Transport Mode)가 적절하다.
- (구성도-B) 터널(VPN) 게이트웨이 간에 보안 채널을 형성하고 있으므로, 터널(VPN) 게이트웨이 구간에 보안 서비스를 제공해 주는 터널 모드(Tunnel Mode)가 적절하다.

0421. ○ △ × 14,1회,기사

다음 보기의 상황을 참고하여 각각의 질문에 답하시오.

보기

사내 보안 담당자는 예산 문제로 예전에 사용하던 VPN 장비를 재사용하기로 하였다. 배치 후의 구축 환경과 증상은 다음과 같다.
- 사내 네트워크는 기존과 달리 NAT 기능을 이용한 사설 IP 환경으로 변경되었다.
- IPsec의 ESP 프로토콜을 사용할 경우에는 정상적으로 동작하였으나, AH 프로토콜을 사용할 경우에는 연결에 문제가 발생하였다.
- 이후 VPN 장비의 IPsec 모듈을 상위 버전으로 업그레이드한 결과, AH 프로토콜을 사용한 경우에도 정상적으로 동작하였다.

1) 현재 상황만을 고려할 때 발생한 문제의 원인을 서술하시오.

2) 이 환경에서 PSK(Pre-Shared Key) 인증 방식을 사용하여 다른 장비와 연결하고자 한다. 이 인증 방식의 장단점을 각각 서술하시오.

정답 및 해설

1) AH 프로토콜은 인증 데이터(ICV: Integrity Check Value) 계산 시 IP 헤더 또는 New IP 헤더의 변경 가능한 필드(예: TTL 필드, Header Checksum 필드, 출발지 IP 필드 등)를 제외한 IP 패킷 전체를 인증한다. 그런데 오래된 IPsec 모듈의 경우 NAT 환경을 고려한 설계가 되어있지 않아, NAT에 의해 변경되는 출발지 IP 주소 정보가 인증 데이터 계산에 포함될 수 있으며, 그 결과 수신 측에서 인증 오류가 발생할 수 있다.
- ESP 프로토콜은 인증 데이터(ICV) 계산 시 IP 헤더 또는 New IP 헤더를 인증 대상에 포함하지 않기 때문에, NAT 환경에서도 AH와 같은 인증 오류가 발생하지 않는다.

2) PSK(Pre-Shared Key, 사전 공유 키) 인증 방식은 통신을 시작하기 전, 송신자와 수신자가 미리 동일한 비밀키를 공유하여 상호 인증을 수행하는 방식으로 장단점은 다음과 같다.
- (장점) PSK 인증 방식은 인증서 기반 방식에 비해 설정이 간단하여 소규모 환경에서 쉽게 상호 인증을 수행할 수 있다.
- (단점) 통신 대상이 증가할수록 비밀키 관리가 어렵고, 키 유출 시 전체 통신 보안에 심각한 문제가 발생할 수 있다.

0422. ○△×

IPsec 프로토콜에서 제공하는 다음 보안 서비스의 의미와 구체적인 방법을 설명하시오.

1) 기밀성(Confidentiality) 보장
2) 비연결형 무결성(Connectionless Integrity) 보장
3) 데이터 원천 인증(Data Origin Authentication, 송신처 인증) 보장
4) 재전송(재현) 공격 방지(Protection Against Replays)
5) 접근 제어(Access Control)
6) 제한적 트래픽 흐름의 기밀성(Limited Traffic Flow Confidentiality) 보장

정답 및 해설

1) 기밀성 보장 : 대칭키 암호를 이용하여 데이터가 제3자에게 노출되더라도 그 내용을 알 수 없도록 보장한다.
   - AH 프로토콜은 기밀성(암호화)을 제공하지 않으며, ESP 프로토콜만 기밀성(암호화)을 제공한다.
2) 비연결형 무결성 보장 : 메시지 인증 코드(MAC)를 이용하여 데이터가 전송 중 위변조되지 않았음을 보장한다.
3) 데이터 원천 인증 보장 : 메시지 인증 코드(MAC)를 이용하여 데이터가 올바른 송신처로부터 전송되었음을 보장한다.
4) 재전송(재현) 공격 방지 : 순서번호(Sequence Number)를 이용하여 이전에 전송된 패킷의 재전송 공격을 방지한다.
5) 접근 제어 : 보안 정책(Security Policy)을 통해 송수신 IP 패킷에 대한 시스템 접근을 제어한다.
6) 제한적 트래픽 흐름의 기밀성 보장 : ESP 프로토콜에 터널 모드를 적용하면 New IP 헤더에 의해 터널 게이트웨이 간 트래픽 흐름 정보는 노출되지만, 원본 IP 헤더는 암호화되어 터널 게이트웨이와 종단 노드 구간의 트래픽 흐름 정보에 대한 기밀성이 보장된다.

0423. ○△× 15.2회.기사

다음은 IPsec을 통해 제공되는 보안 서비스들이다. 나머지 네 가지에 대한 명칭과 의미를 기술하시오.

① ( )
② ( )
③ ( )
④ ( )
⑤ 접근 제어 : 중요한 정보 및 시스템에 대한 접근을 제어한다.
⑥ 제한적 트래픽 흐름의 기밀성 : IPsec의 터널 모드가 적용된 ESP 프로토콜을 통해 원본 IP 패킷(Original IP 헤더 및 Payload) 전체를 암호화함으로써 최초 출발지 및 최종 목적지 정보에 대한 기밀성을 보장해 준다.

정답 및 해설

① 기밀성(Confidentiality) : 데이터가 제3자에 노출되더라도 그 내용을 알 수 없도록 보장해 준다.
   - 대칭키 암호를 이용하여 기밀성을 보장해 준다.
   - AH 프로토콜은 기밀성(암호화)을 제공하지 않으며, ESP 프로토콜만 기밀성(암호화)을 제공한다.
② 비연결형 무결성(Connectionless Integrity) : 데이터가 전송 중 위변조되지 않았음을 보장해 준다.
   - 메시지 인증 코드(MAC)를 이용하여 IP 패킷별로 순서에 상관없이 무결성을 보장해 준다.
③ 데이터 원천 인증(Data Origin Authentication, 송신처 인증) : 데이터가 올바른 송신처로부터 전송되었음을 보장해 준다.
   - 메시지 인증 코드(MAC)를 이용하여 데이터 원천 인증(송신처 인증)을 보장해 준다.
④ 재전송(재현) 공격 방지(Protection Against Replays) : 이전에 전송된 패킷의 재전송 공격을 방지한다.
   - IP 패킷별 순서번호(Sequence Number)를 이용하여 재전송(재현) 공격을 방지해준다.

0424. ○△× 25.2회.산기

TLS(Transport Layer Security) 프로토콜의 사용 목적을 '상호 호환성', '확장성', '효율성' 관점에서 각각 서술하시오.

정답 및 해설

TLS 프로토콜은 상호 호환성, 확장성, 효율성을 고려하여 설계된 보안 프로토콜로, 이를 관점별로 정리하면 다음과 같다.

1) (상호 호환성 관점) TLS는 다양한 운영체제, 애플리케이션, 하드웨어 장치 간에 안전한 통신을 보장하는 표준화된 프로토콜이다.
2) (확장성 관점) TLS는 기술 발전이나 새로운 보안 요구 사항에 따라 기능을 유연하게 확장할 수 있다.
   - 새로운 암호 알고리즘이나 인증 기법을 추가하더라도 기존 구조와 충돌 없이 적용할 수 있다.
3) (효율성 관점) TLS는 보안을 강화하면서도 통신 지연과 리소스 소모를 최소화하도록 설계되어 있다.
   - 핸드셰이크 과정을 최적화하고, 실제 데이터 전송 시에는 대칭키 암호화를 사용하여 빠른 성능을 유지한다.

0425. ○△× 14.1회.산기

시스템을 관리하면서 보안을 위해 HTTP 대신 HTTPS를 TELNET 대신 SSH를 사용하도록 권장하고 있다. 다음 질문에 대한 적절한 답을 간단히 서술하시오.

1) HTTP 나 TELNET을 사용할 때 노출될 수 있는 공격의 이름은 무엇인가?

2) HTTP 대신 HTTPS, TELNET 대신 SSH를 사용하는 것이 안전한 이유는 무엇인가?

정답 및 해설

1) HTTP와 TELNET의 경우 평문 통신을 수행하기 때문에 중간자 공격(MITM)에 취약하다. 즉 통신의 양 당사자 사이에 공격자가 패킷을 스니핑 또는 위변조하기 쉽다.
2) HTTPS와 SSH의 경우 암호화된 통신을 수행하기 때문에 중간에 공격자에 의해 패킷이 스니핑된다고 해도 그 내용을 알 수가 없다. 즉 기밀성을 보장해 준다.

0426. ○△×

라우터의 인터페이스에 'no ip unreachables' 설정이 필요한 이유를 보안 관점에서 두 가지로 서술하시오.

정답 및 해설

1) 'no ip unreachables' 설정의 의미
- 라우터의 인터페이스에 'no ip unreachables'를 설정하게 되면 전송할 수 없는 패킷이 들어와도(패킷을 차단해도) ICMP Unreachable 메시지 응답을 보내지 않는다.
- 설정하지 않으면 기본적으로 라우터는 최초 출발지로 패킷 폐기에 따른 ICMP Unreachable 메시지 응답을 보낸다.
- (설정 예) (config-if) # no ip unreachables

2) 설정이 필요한 이유(보안 관점)
- ICMP Unreachable 메시지 응답을 차단하지 않으면 악의적인 대량의 패킷을 통해 ICMP Unreachable 메시지 응답에 따른 라우터의 부하를 유발할 수 있다.
- ICMP Unreachable 메시지 응답이 공격자의 포트 스캐닝 공격 시 중요한 정보로 사용되기 때문에 이를 차단하는 것이 보안상 안전하다.

0427. ○△×

Access-List와 함께 유용하게 사용할 수 있는 라우터에서 사용하는 필터링 기법 중 블랙홀 필터링(Blackhole Filtering)이라는 기법이 있다. 1) 이 기법에 대한 설명과 2) DDoS 공격 상황에서 블랙홀 필터링 기법이 갖는 문제점에 관해 간략히 서술하시오.

정답 및 해설

1) 블랙홀 필터링(Blackhole Filtering) 기법 : Null 라우팅 기법이라고도 함
- 특정 목적지 IP 또는 IP 대역에 대한 비정상적인 접근(예, 디도스 공격)이 감지되었을 때 해당 IP 또는 IP 대역으로의 접근을 차단하기 위해 Null 인터페이스(가상의 인터페이스)로 패킷을 보내 통신이 이루어지지 않도록 하는 필터링 방식이다.
- (설정 형식) ip route 〈차단하고자 하는 목적지 IP 또는 IP 대역〉 〈netmask〉 Null 0
- (설정 예) (config) # ip route 211.1.1.1 255.255.255.255 Null 0
  - 'Null 0'라는 가상의 인터페이스로 211.1.1.1을 목적지로 하는 IP 패킷을 보낸다(차단한다).

2) 문제점
- 라우터는 패킷이 Null 인터페이스로 보내질 때마다 최초 출발지로 패킷 차단에 따른 ICMP Unreachable 메시지를 발송하게 되는데, 만약 필터링하는 패킷이 많으면 라우터에 과부하를 유발할 수 있다.
- 따라서 Null 인터페이스에 ICMP Unreachable 메시지를 응답하지 않도록 설정하는 것이 필요하다.
  - (설정 예) (config-if) # no ip unreachables

0428. ○△×

라우터에서 다음과 같이 IP 소스 라우팅(source routing)을 금지하기 위하여 아래와 같은 명령어를 입력했다. IP 소스 라우팅에 대하여 설명하고 아래와 같은 명령어를 입력하지 않았을 때 발생할 수 있는 보안상 문제점은 무엇인지 설명하시오.

보기

```
(config) # no ip source-route
```

정답 및 해설

1) IP 소스 라우팅(source routing)
- IP 패킷이 목적지에 도달하기 위한 경로는 라우터에 의해 결정된다. 패킷 자체는 목적지 주소(destination address)만 가지고 있을 뿐 목적지에 도달하기 위한 경로에 대한 어떠한 정보도 가지고 있지 않은데 송신자 쪽에서 IP 옵션 헤더를 이용하여 라우팅 경로 목록을 직접 정의하면 지정된 경로로 라우팅이 되도록 할 수 있다. 이를 IP 소스 라우팅(source routing)이라 한다.

2) IP 소스 라우팅 허용 시 보안상 문제점
- IP 소스 라우팅을 허용하면 공격자가 정상적인 라우팅을 통해서는 외부에서 직접 접근이 불가능한 공격 대상 시스템을 IP 소스 라우팅을 통해 우회하여 접근할 수 있는 보안상 문제점이 발생한다.

0429. ○△×

다음은 Router(Cisco)의 access-list 설정 부분이다. 차례에 맞게 설정 내용에 대하여 정확하게 기술하시오.

보기

```
Router> en
Password:
Router#
Router# conf t
Router(config)# access-list 150 deny tcp any any eq 445
Router(config)# access-list 150 deny tcp 192.168.1.0 0.0.0.255 host 100.100.1.1 eq 80
Router(config)# access-list 150 deny udp host 192.168.2.5 100.100.1.0 0.0.0.0.255
                range 100 200
Router(config)# access-list 150 deny ip host 192.168.1.3 host 100.100.1.2
Router(config)# access-list 150 permit tcp any any
Router(config)# ^Z
Router# conf t
Router(config)# int serial0
Router(config-if)# ip access-group 150 in
Router(config)# ^Z
```

정답 및 해설

[전체적인 설정 과정]

1) enable(en)로 Privileged Mode로 전환하였다.
2) 라우터 설정을 위해 config terminal(conf t) 명령어로 global configuration 모드로 전환하였다.
3) (ACL 150번의 첫 번째 규칙) TCP 프로토콜의 모든 출발지 및 목적지 IP에 대해 445번 목적지 포트로의 접근을 거부한다(CISF(SMB) 서비스 접근 차단).
4) (ACL 150번의 두 번째 규칙) TCP 프로토콜의 출발지 IP가 192.168.1.0/24대역이고 목적지 IP가 100.100.1.1인 패킷의 80번 목적지 포트로의 접근을 거부한다.
5) (ACL 150번의 세 번째 규칙) UDP 프로토콜의 출발지 IP가 192.168.2.5이고 목적지 IP가 100.100.1.0/24대역인 패킷의 100~200번 목적지 포트로의 접근을 거부한다.
6) (ACL 150번의 네 번째 규칙) 출발지 IP가 192.168.1.3이고 목적지 IP가 100.100.1.2인 패킷을 거부한다.
7) (ACL 150번의 다섯 번째 규칙) TCP 프로토콜의 모든 패킷을 허용한다.
8) serial0 인터페이스(int)에 ACL 150번 규칙(access-group 150)을 인바운드(in) 트래픽에 적용한다.

[ACL 적용 순서]

- ACL 적용의 순서는 위에서 아래로 적용된다. 즉 라우터 인터페이스에 적용한 ACL의 첫 번째 규칙부터 패킷을 비교하여 조건에 맞으면 이에 따른 허용/거부가 이루어지고, 조건이 맞지 않으면 다음 규칙과 비교한다. 비교하는 과정은 조건이 맞을 때까지 계속 이루어지게 된다.

0430. ○△×

다음 보기는 라우터(Cisco)에서 설정하는 명령이다. 각 번호의 작업에 대해 자세하게 기술하시오.

보기

(1) enable secret endjfi78

---

(2) access-list 50 permit host 192.168.10.1
(2) access-list 50 deny any
(2) snmp-server community sdfj94js ro 50

---

(3) logging on
(3) logging trap debugging
(3) logging 192.168.10.13.

정답 및 해설

[1번 항목 설정]

- Privileged Mode로 전환 시 사용할 암호를 endjfi78로 설정한다(암호문으로 저장).

[2번 항목 설정]

- ACL 50번 규칙 : 출발지 IP가 192.168.10.1인 호스트를 제외하고 모든 호스트를 거부한다.
- snmp-server를 활성화하고(SNMP 서비스 사용) community string을 sdfj94js로 설정하고 권한은 Read Only(ro)로 하여 ACL 50번을 적용한다.
- community string은 SNMP 서버와 클라이언트가 데이터를 교환하기 전에 인증을 위해 사용하는 일종의 패스워드로, 초기값으로 public 또는 private가 설정되어 있다. 이를 그대로 사용하는 것은 패스워드를 사용하지 않는 계정을 사용하는 것 이상으로 위험하다. 따라서 추측하기 어렵고 의미가 없는 문자열로 community string을 설정(변경)해야 한다.
- SNMP에서는 RO(Read Only)와 RW(Read Write) 모드를 제공한다. 쓰기 권한(RW 모드)이 있으면 중요 설정을 수정할 수 있는 등 심각한 보안 문제를 유발할 수 있으므로 되도록 사용 자제를 권고한다.
- SNMP 서비스가 불필요한 경우, 이를 비활성화하지 않으면 비인가자가 SNMP에 무단 접근하여 설정 파일 열람 및 수정이나 정보 수집 및 관리자 권한 획득, DoS 등 다양한 형태의 공격이 가능하다. 따라서 네트워크 장비의 SNMP 서비스를 사용하지 않으면 비활성화하도록 한다.
  - (설정 예) (config) # no snmp-server

[3번 항목 설정]

- 로깅 기능을 활성화하고(on) 로깅 수준을 디버깅(debugging)으로 설정하고 로그를 남길 원격지 로그 서버(원격지 syslog 서버)의 IP를 192.168.10.13으로 설정한다.

0431. ○△×

다음은 라우터의 Simple Access-list에 관한 내용이다. 문제점을 찾아 서술하고, 수정하시오.

보기

```
access-list 12 permit 123.123.0.0  0.0.255.255
access-list 12 deny   123.123.1.0  0.0.0.255
access-list 12 deny   123.123.2.0  0.0.0.255
```

정답 및 해설

첫 번째 규칙에서 출발지 IP를 123.123.0.0/16 대역으로 허용했기 때문에 두 번째와 세 번째 거부정책은 적용되지 않는다. 두 번째와 세 번째 거부정책을 적용하기 위해서는 아래와 같이 첫 번째 규칙을 가장 마지막에 설정한다.

- access-list 12 deny 123.123.1.0 0.0.0.255
- access-list 12 deny 123.123.2.0 0.0.0.255
- access-list 12 permit 123.123.0.0 0.0.255.255

0432. ○△× 13.1회.산기

다음 시스코 라우터 설정 과정은 (1) 무엇을 수행하기 위한 것이며, (2) 수행 과정에 맞게 순서를 적으시오.

보기

ⓐ Router(config-line)# exit
ⓑ Router(config)# line vty 0
ⓒ Router(config-line)# password algisa
ⓓ #conf t

정답 및 해설

1) vty(virtual terminal) 포트는 원격지에서 텔넷(Telnet) 등을 통해 접속하는 가상 터미널 포트로 접속 패스워드로 algisa를 설정하고 있다.
2) d, b, c, a

0433. ○△× 24.1회.산기

RIP 라우팅 프로토콜의 느린 수렴 문제를 개선하기 위해 Triggered Update, Holddown Timer, Split Horizon, Route Poisoning 등의 방안이 있다. 이 중에서 Triggered Update와 Route Poisoning 방안의 의미를 서술하시오.

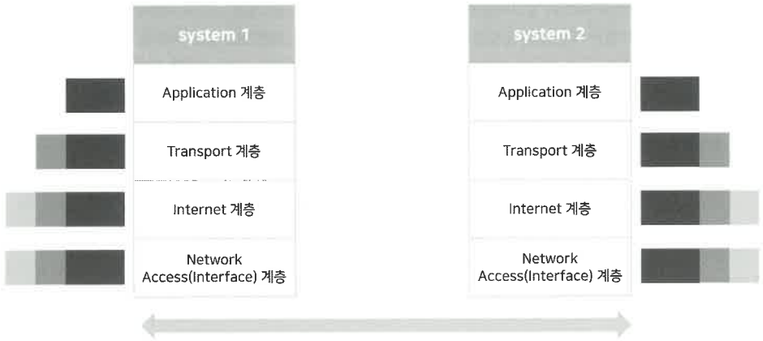
정답 및 해설

1) RIP(Routing Information Protocol) 라우팅 프로토콜 개요
   - 거리 벡터(distance vector) 알고리즘에 기초하여 개발된 라우팅 프로토콜로 소규모 네트워크에 주로 사용된다.
   - 최대 15홉 수(16홉은 무한대로 도달할 수 없는 목적지를 의미)로 제한하고 경로 비용을 오로지 홉 수(hop count)만으로 판단하므로 속도나 거리 지연 등을 고려하지 않아 최적의 경로 산정에 비효율적이다.
2) RIP 프로토콜의 주요 문제점
   - 늦은 수렴성(slow convergence) : 인접 라우터끼리 주기적으로(30초 간격) 라우팅 정보를 업데이트하므로 몇 개의 라우터만 지나도 수분 이상 소요되어 네트워크 변화 상태에 대한 인식 속도가 느리다.
   - 라우팅 루프 : 늦은 수렴성에 의해 네트워크 장애(down) 등의 정보가 늦게 전달되어 잘못된 경로에 의한 무한 루프(infinite loop) 등이 발생할 수 있다.
   - 라우팅 트래픽 부하 : 전체 경로를 담은 라우팅 테이블 정보를 주기적으로 브로드캐스트하므로 트래픽 부하가 발생한다.
3) RIP 프로토콜 문제점에 대한 주요 해결책
   - Triggered Update : 주기적인 업데이트(30초 간격) 외에도 네트워크에 변화가 발생하면(라우팅 정보가 변경되면) 즉시 인접 라우터에 정보를 전달한다.
   - Holddown Timer : 일정 시간 라우팅 정보를 수신하지 않음으로써(라우팅 정보 갱신 유보) 잘못된 라우팅 정보로 갱신되는 것을 방지한다.
   - Split Horizon : 라우팅 정보를 수신한 인터페이스로 다시 라우팅 정보를 재전송하지 않음으로써 라우터 간의 라우팅 정보 루핑을 방지한다.
   - Route Poisoning : 특정 네트워크에 장애(down)가 발생하면 해당 네트워크의 홉 카운트(매트릭)를 16(무한대, 도달 불가능)으로 하여 즉시 인접 라우터에 정보를 전달한다.

03. 네트워크 보안 실무형

0434. ○ △ × 23.4회.산기

다음 보기는 2개의 시스템 간 TCP/IP 스택을 통해 애플리케이션 계층부터 네트워크 액세스 계층까지의 데이터 교환 방식을 보여주고 있다. 다음 각각의 질문에 답하시오.



1) PDU(Protocol Data Unit)의 구성요소를 쓰시오.

2) 전송 계층(Transport Layer)의 TCP와 UDP 프로토콜의 PDU를 쓰시오.

3) 캡슐화(Encapsulation) 과정과 역캡슐화(Decapsulation) 과정을 쓰시오.

정답 및 해설

1) PDU(Protocol Data Unit)는 PCI와 SDU로 구성되어 있다.
- PDU는 계층별 프로토콜의 데이터 전송단위를 말하며 PCI(Protocol Control Information)와 SDU(Service Data Unit)로 구성된다.
- PCI(Protocol Control Information) : 프로토콜 제어 정보(일반적으로 헤더 또는 헤더와 트레일러로 구성)
- SDU(Service Data Unit) : 전송 데이터(페이로드)

2) TCP : 세그먼트(Segment), UDP : 데이터그램(Datagram)

3) 캡슐화 및 역캡슐화 과정
- 캡슐화(Encapsulation) 과정 : 상위 계층 프로토콜로부터 전달받은 데이터에 해당 계층 프로토콜의 기능수행에 필요한 제어 정보(헤더 또는 헤더와 트레일러)를 추가해서 새롭게 데이터를 완성한 후 하위 계층으로 전달한다.
- 역캡슐화(Decapsulation) 과정 : 하위 계층 프로토콜로부터 전달받은 데이터에 해당 계층 프로토콜의 제어 정보(헤더 또는 헤더와 트레일러)를 제거한 후 상위 계층 프로토콜로 전달한다.

0435. ○ △ × 25.4회.산기

IPv4 프로토콜에서 패킷을 분할하여 전송하려고 한다. 상위계층에서 전달받은 전체 데이터는 400바이트이고 IP 패킷의 최대 크기(IP 헤더를 포함한 최대 크기)는 128바이트이다. 분할된 각 패킷에 대하여 전체 길이, MF 플래그, Fragment Offset을 계산하시오.
(단, IP 헤더는 옵션과 패딩이 없음)

속성	전체 길이	MF 플래그	Fragment Offset
첫 번째 패킷			
두 번째 패킷			
세 번째 패킷			
네 번째 패킷			

정답 및 해설

1) 문제에서 제시한 IP 단편화 조건은 다음과 같다.
- IP 헤더 길이 : 20바이트(옵션/패딩이 없으므로 기본 헤더 20바이트)
- IP 단편 데이터의 최대 크기 : 128바이트 − 20바이트 = 108바이트
- IP 단편 데이터 길이는 8의 배수여야 하므로(Fragment Offset이 8바이트 단위로 설정됨) 108바이트 이하에서 8의 배수인 104바이트(13*8)가 최대 길이가 된다.

2) 각 단편의 계산 방식은 다음과 같다.
- 전체 길이 : 20바이트(IP 헤더 길이) + 데이터 크기
- MF 플래그 : More Fragment 플래그(추가 단편 여부)로 마지막 단편만 0, 나머지 단편은 1로 설정
- Fragment Offset : 원본 데이터에서 각 단편 데이터의 상대 위치(0부터 시작)로 8바이트 단위로 설정한다. 이전 단편 데이터의 누적 길이에 8을 나누면 현재 단편의 오프셋을 계산할 수 있다.

3) 계산 결과

분할 패킷	전체 길이	MF 플래그	Fragment Offset
첫 번째 패킷	20 + 104 = 124	1	0 / 8 = 0
두 번째 패킷	20 + 104 = 124	1	104 / 8 = 13
세 번째 패킷	20 + 104 = 124	1	(104 + 104) / 8 = 26
네 번째 패킷	20 + 88 = 108	0	(104 + 104 + 104) / 8 = 39

0436. ○△× 17.2회.기사

알기사 교육기관의 시스템 관리자는 시스템(Cent OS 5.8) 점검을 한 결과 다음과 같은 결과를 확인할 수 있었다. 다음 각 질문에 답하시오.

```
root@CentOS5:~
파일(F) 편집(E) 보기(V) 터미널(T) 탭(B) 도움말(H)
[root@CentOS5 ~]# uname -a
Linux CentOS5.8 2.6.18-308.11.1.el5 #1 SMP Tue Jul 10 08:49:28 EDT 2012 i
686 i686 i386 GNU/Linux
[root@CentOS5 ~]#
[root@CentOS5 ~]# ifconfig eth0
eth0      Link encap:Ethernet  HWaddr 00:0C:29:56:B6:38
          inet addr:10.10.10.20  Bcast:10.10.10.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fe56:b638/64 Scope:Link
          UP BROADCAST RUNNING PROMISC MULTICAST  MTU:1500  Metric:1
          RX packets:25593 errors:0 dropped:0 overruns:0 frame:0
          TX packets:29730 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:5020328 (4.7 MiB)  TX bytes:56476441 (53.8 MiB)

[root@CentOS5 ~]#
```

1) 예상되는 공격 명칭과 그 이유를 쓰시오.

2) 위 문제를 해결하기 위한 명령어를 완성하시오.

ifconfig eth0 ( )

3) (1) 상태의 발생 시점을 찾기 위한 로그의 정확한 경로(파일명 포함)를 쓰시오.

정답 및 해설

1) ifconfig 명령 결과를 살펴보면 eth0 네트워크 인터페이스에 PROMISC가 설정된 것을 볼 수 있다. 네트워크 인터페이스의 promiscuous mode(무차별 모드)는 유입된 프레임(패킷)의 목적지 MAC 주소와 무관하게 모든 프레임(패킷)을 수신하는 동작 모드를 말한다. 따라서 자신이 목적지가 아닌 프레임(패킷)도 모두 수신하기 때문에 스니핑(sniffing) 공격이 발생한 것으로 판단된다.

2) –promisc

3) /var/log/messages

0437. ○△× 22.1회.기사 24.2회.기사

알기사 교육기관의 시스템 관리자는 리눅스 시스템의 로그파일(/var/log/messages)을 점검한 결과 다음과 같은 결과를 확인하였다. 다음 각 질문에 답하시오.

```
root@Fedora11:/etc/httpd/conf    root@Fedora11:/var/log/snort
[root@Fedora11 conf]# cat /var/log/messages | grep promiscuous
Nov  1 00:06:38 Fedora11 kernel: device eth1 entered promiscuous mode
[root@Fedora11 conf]#
```

1) 로그 상에 기록된 promiscuous mode의 의미를 쓰시오.

2) promiscuous mode로 진입 시 발생할 수 있는 공격은 무엇인가?

3) 해당 공격에 대응하는 방안을 1가지 이상 쓰시오.

정답 및 해설

1) 네트워크 인터페이스의 promiscuous mode(무차별 모드)는 유입된 프레임(패킷)의 목적지 MAC 주소와 무관하게 모든 프레임(패킷)을 수신하는 동작 모드를 말한다.

2) 네트워크 인터페이스가 promiscuous mode(무차별 모드)로 설정되면 자신이 목적지가 아닌 프레임(패킷)도 모두 수신하기 때문에 네트워크 스니핑(sniffing) 공격이 발생할 수 있다.

3) 주요 대응 방안을 살펴보면 다음과 같다.

- 네트워크 스니핑을 통해 통신 내용을 알 수 없도록 암호화(보안) 프로토콜 또는 암호화 프로그램을 사용하여 통신에 사용되는 모든 데이터를 암호화한다.
- 허브(더미 허브) 장비에 비해 상대적으로 네트워크 스니핑 공격에 안전한 스위치(스위칭 허브) 장비를 이용한다.
- 스니핑 탐지 도구를 이용하여 악의적인 스니핑이 발생하는지 지속해서 점검한다.

0438. ○ △ × 14.2회.산기

다음과 같이 구성된 네트워크에서 시스템 X는 시스템 A가 보내거나 받는 모든 통신을 스니핑하기 위해 조작된 가짜 ARP Reply 메시지를 시스템 A와 라우터 R에 보냈고 성공하였다. 다음 1) 2) 3)의 질문에 대해 답하시오.

시스템	IP 주소	MAC 주소
A	A_IP	A_MAC
X	X_IP	X_MAC
R	R_IP	R_MAC

1) 시스템 A의 ARP 테이블에서 라우터 R과 시스템 X의 IP와 MAC 정보

2) 시스템 X의 ARP 테이블에서 시스템 A와 라우터 R의 IP와 MAC 정보

3) 라우터 R의 ARP 테이블에서 시스템 A와 시스템 X의 IP와 MAC 정보

정답 및 해설

1) 시스템 A의 경우 라우터 R의 MAC 정보가 공격자(X)의 MAC 정보로 조작된다.
- R : R_IP, X_MAC
- X : X_IP, X_MAC

2) 공격자(X)의 경우 정상적인 A와 R의 MAC 정보를 가지고 있다.
- R : R_IP, R_MAC
- A : A_IP, A_MAC

3) 라우터(R)의 경우 시스템 A의 MAC 정보가 공격자(X)의 MAC 정보로 조작된다.
- A : A_IP, X_MAC
- X : X_IP, X_MAC

0439. ○ △ × 15.2회.기사

알기사 교육기관의 네트워크 관리자는 평상시 게이트웨이(라우터)의 IP 주소(10.10.24.1)와 MAC 주소(11-11-11-11-11-11)를 알고 있다. 시스템을 점검한 결과 보기와 같은 결과를 확인할 수 있었다. ① 이 공격의 명칭을 제시하고, ② 그 이유는 무엇이고, ③ 공격자의 IP로 추정되는 것은 무엇이며, ④ 컴퓨터의 도스창을 통해 지금 해결 가능한 명령어는 무엇인지 설명하시오.

보기

```
C:₩ arp -a
  Interface Address      Physical Address      Type
  10.10.24.1             aa-aa-aa-aa-aa-aa     dynamic
  10.10.24.4             aa-aa-aa-aa-aa-aa     dynamic
  10.10.24.5             bb-bb-bb-bb-bb-bb     dynamic
  10.10.24.6             cc-cc-cc-cc-cc-cc     dynamic
```

정답 및 해설

① ARP Redirect 공격(또는 ARP Spoofing 공격)

② 점검한 시스템의 ARP Cache Table을 보면 게이트웨이(라우터, IP : 10.10.24.1)의 MAC 주소가 공격자로 의심되는 호스트(IP : 10.10.24.4)의 MAC 주소로 조작된 것을 볼 수 있다. 따라서 ARP Redirect(또는 ARP Spoofing) 공격을 받은 것으로 판단된다.

③ 조작된 게이트웨이(라우터)의 MAC 주소를 가지고 있는 10.10.24.4 IP 주소 호스트

④ 다음 명령을 수행하여 ARP Cache Table에 게이트웨이(라우터)의 MAC 주소 정보를 정적(static)으로 구성한다.
- (명령어) arp -s 10.10.24.1 11-11-11-11-11-11

※ (참고) ARP 스푸핑(Spoofing) 공격 Vs ARP 리다이렉트(Redirect) 공격
- ARP 스푸핑 공격과 ARP 리다이렉트 공격은 공격자가 특정 호스트 인척 속이는 것인지 또는 대상 네트워크의 게이트웨이(라우터) 인척 속이는 것인지에만 차이가 있을 뿐 동일한 형태의 공격입니다. 따라서 ARP 리다이렉트 공격을 별도로 분류하지 않고 모두 ARP 스푸핑 공격으로 설명하는 자료도 많이 있습니다.
- 위 문제도 ARP 스푸핑 공격으로 답안을 작성해도 정답으로 인정될 것으로 판단됩니다.

0440. ○ △ × 24.1회.기사

알기사 직원 PC의 인터넷이 갑자기 느려져 MAC 테이블(ARP 캐시 테이블)을 확인해 보니 보기와 같은 결과를 확인할 수 있었다. 각각의 질문에 답하시오.

보기

Interface Address	Physical Address	Type
192.168.100.1	aa-aa-aa-aa-aa-aa	dynamic
192.168.100.5	aa-aa-aa-aa-aa-aa	dynamic
192.168.100.10	bb-bb-bb-bb-bb-bb	dynamic
192.168.100.15	cc-cc-cc-cc-cc-cc	dynamic
192.168.100.20	dd-dd-dd-dd-dd-dd	dynamic

1) 위 결과를 출력하기 위한 명령어를 쓰시오.
2) 어떤 공격이 의심되는가?
3) 해당 공격이라 판단한 이유는 무엇인가?
4) 192.168.100.1 호스트의 실제 MAC 주소는 a1-b1-c1-d1-e1-g1이다. 네트워크 관리자가 설정할 수 있는 명령어를 쓰시오.

정답 및 해설

1) arp -a
2) ARP Spoofing 공격
3) 알기사 직원 PC의 ARP Cache Table을 살펴보면 192.168.100.1 IP 호스트의 MAC 주소가 공격자로 의심되는 호스트(IP : 192.168.100.5)의 MAC 주소로 조작된 것을 볼 수 있다. 따라서 ARP Spoofing 공격을 받은 것으로 판단된다.
4) 다음 명령을 수행하여 ARP Cache Table에 192.168.100.1 IP의 MAC 주소 정보를 정적(static)으로 구성한다.
   - (명령어) arp -s 192.168.100.1 a1-b1-c1-d1-e1-g1

※ (참고) 알기사 직원 PC의 인터넷이 느려진 상황이므로 게이트웨이(라우터)와의 통신에 스니핑이 발생했고 조작된 MAC 주소의 IP인 192.168.100.1은 게이트웨이(라우터)의 IP 주소로 추측됩니다. 따라서 ARP Redirect 공격으로 답안을 작성해도 정답으로 인정될 것으로 판단됩니다.

0441. ○ △ × 15.2회.산기

알기사 교육기관의 직원은 보안 담당자로부터 ARP 스푸핑 공격이 192.168.10.2 시스템에 발생했으며, 올바른 MAC 주소는 00-11-12-aa-bb-cc 라는 내용의 이메일을 받았다. 알기사 직원의 윈도우 시스템에서 명령 (1)을/를 수행하여 arp 정보를 확인한 결과는 아래와 같다.

보기

C:₩ (1)
인터페이스 192.168.10.15 ---------0xa

인터넷주소	물리적주소	유형
192.168.10.2	01-23-45-67-89-ab	동적
192.168.10.3	aa-23-45-67-89-ab	동적

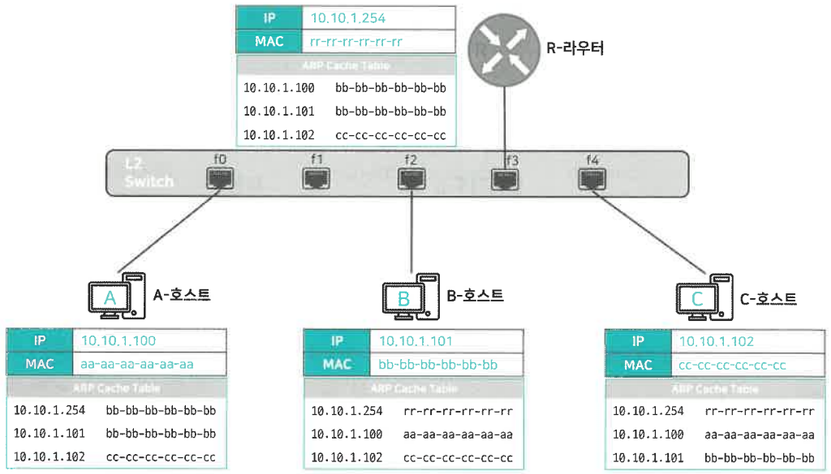
만일 알기사 직원의 PC가 ARP 스푸핑 공격을 받았을 경우 (2) 어떻게 하면 해당 IP에 대한 ARP 스푸핑 공격에 대응할 수 있는가? 또 이를 위해 (3) 수행해야 할 명령을 제시하시오.

정답 및 해설

1) arp -a
2) ARP Cache Table에 해당 IP의 MAC 주소 정보를 정적(static)으로 설정한다.
3) arp -s 192.168.10.2 00-11-12-aa-bb-cc

0442. ○ △ × 19.1회.산기

알기사 시스템 담당자는 내부 시스템을 점검한 결과 아래와 같은 사실을 확인하였다. 다음 각각의 질문에 답하시오.



1) 어떠한 공격이 발생했는지 쓰시오.

2) 피해자 호스트는 누구인가?

3) 공격자 호스트는 누구인가?

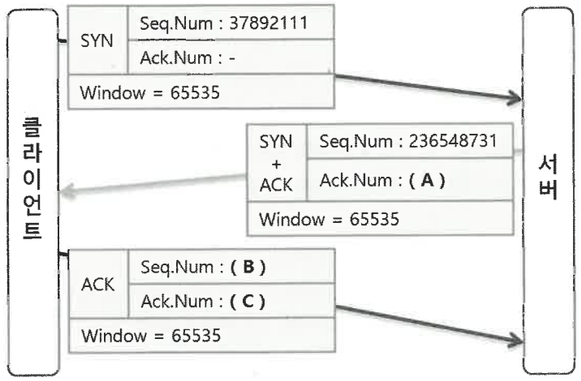
4) 해당 공격에 대응하는 방법을 쓰시오.

정답 및 해설

1) ARP Redirect 공격(또는 ARP Spoofing 공격)
2) A-호스트
3) B-호스트
4) 대응 방법은 다음과 같다.
   - 중요 호스트에 대해서는 ARP Cache Table을 정적(static)으로 설정하여 동적(dynamic)으로 캐시 정보를 조작하지 못하도록 한다.
   - 네트워크상의 ARP 트래픽을 실시간으로 모니터링하는 도구(Arpwatch 등)를 이용하여 ARP 조작 트래픽을 탐지한다.

0443. ○ △ × 16.2회.기사

다음은 TCP 연결 설정 과정인 3-Way Handshake 과정에 관한 내용이다.
각각의 빈칸에 적절한 Sequence Number와 Acknowledgment Number를 쓰시오.



정답 및 해설

3-way handshake 동작 방식

1) 최초 클라이언트는 연결 요청(SYN)과 랜덤한 초기순서번호인 ISN(Initial Sequence Number)을 Sequence Number(Seq.Num) 필드에 설정하여 보낸다.
2) 서버 측에서는 클라이언트의 연결 요청(SYN)에 대한 확인 응답(ACK)과 함께 클라이언트로 연결 요청(SYN)과 랜덤한 초기순서번호인 ISN을 Sequence Number(Seq.Num) 필드에 설정하여 보낸다.
   - ACK 응답 시 Acknowledgment Number(Ack.Num) 필드에 클라이언트가 보낼 다음 순서번호(SYN 요청 시 보낸 Seq.Num+1)인 37892112를 설정한다.
3) 클라이언트가 서버의 연결 요청(SYN)에 대한 확인 응답(ACK)을 보내면 연결 설정 과정은 완료된다.
   - 클라이언트는 최초 SYN 요청 시 설정한 Sequence Number(Seq.Num)에 1 증가한 값(서버에서 ACK 응답 시 설정한 Acknowledgment Number(Ack.Num))인 37892112를 Sequence Number로 설정한다.
   - ACK 응답 시 Acknowledgment Number(Ack.Num) 필드에 서버가 보낼 다음 순서번호(SYN 요청 시 보낸 Seq.Num + 1)인 236548732를 설정한다.

정답 (A) 37892112 (B) 37892112 (C) 236548732

0444. ○△× 17.2회.기사

다음은 TCP 연결 설정 과정(3-way handshake)과 연결 종료 과정(4-way handshake)의 동작 방식에 대한 설명이다. 빈칸에 적절한 TCP 플래그 비트와 순서번호(Sequence Number)를 채우시오. (TCP 플래그 비트는 URG, ACK, PSH, RST, SYN, FIN 순으로 되어있음)

보기

(1) TCP 연결 설정 과정

[Client -> Server] , TCP Flag [①] , SEQ (②) , ACK (0)
[Server -> Client] , TCP Flag [③] , SEQ (④) , ACK (124)
[Client -> Server] , TCP Flag [⑤] , SEQ (124) , ACK (790)

(2) TCP 연결 종료 과정

[Client -> Server] , TCP Flag [010001] , SEQ (1234) , ACK (6789)
[Server -> Client] , TCP Flag [⑥] , SEQ (6789) , ACK (1235)
[Server -> Client] , TCP Flag [⑦] , SEQ (6789) , ACK (1235)
[Client -> Server] , TCP Flag [010000] , SEQ (1235) , ACK (6790)

정답 및 해설

① 000010 ② 123 ③ 010010 ④ 789 ⑤ 010000 ⑥ 010000 ⑦ 010001

0445. ○△× 15.1회.산기

해커는 공격을 본격적으로 시도하기 전, 운영 중인 서버의 운영체제 및 서버가 제공하는 서비스를 확인하기 위하여 Nmap 스캐닝 도구를 사용할 수 있다. 다음 Nmap 옵션의 용도를 쓰시오.

① nmap -sP , ② nmap -sS , ③ nmap -sU , ④ nmap -sF , ⑤ nmap -sN
⑥ nmap -O , ⑦ nmap -p

정답 및 해설

① sP 옵션 : Ping 스캔, 최신 버전은 -sn(No Port Scan) 옵션으로 변경됨
② sS 옵션 : TCP SYN(Half-Open) 스캔
③ sU 옵션 : UDP 스캔
④ sF 옵션 : TCP FIN 스캔
⑤ sN 옵션 : TCP NULL 스캔
⑥ O 옵션 : 대상 호스트의 운영체제(OS) 정보 스캔
⑦ p 옵션 : 대상 호스트에서 스캔할 포트 번호 또는 서비스명을 지정하는 옵션

0446. ○△× 20.1회.산기

다음 보기는 Nmap을 이용한 포트 스캔(Port Scan) 명령이다. 각 질문에 답하시오.

[Nmap 포트 스캔]
#nmap -v -O -sS www.example.com

(1) 어떤 포트 스캔 기법을 시도하는가?
(2) 위 포트 스캔 기법의 보안 관점 특징을 쓰시오.
(3) 포트 스캔 이외에 어떤 추가적인 정보를 확인할 수 있는가?
(4) nmap에 "-b hostname" 인자를 사용하면 어떤 기능을 수행하는가?

정답 및 해설

1) TCP SYN(Half-Open) 스캔
2) TCP SYN(Half-Open) 스캔은 TCP 연결 설정 과정이 완료되기 전에 포트의 오픈 여부를 확인하는 방식으로, 대상 시스템에 연결 로그가 남지 않는 스텔스 스캔(Stealth Scan) 특징을 가진다.
3) -O 옵션을 통해 대상 호스트의 운영체제(OS) 정보를 확인할 수 있다.
4) 대상 호스트에 대해 FTP Bounce 스캔을 수행할 수 있다. 이는 FTP PORT 명령을 악용하여 내부 FTP 서버를 중계지로 사용함으로써, 방화벽 뒤에 있는 내부 호스트를 스캔하는 기법이다.

※ (참고) nmap -v 옵션(Verbose)은 스캔 수행 과정과 결과를 상세하게 출력하기 위한 옵션이다.

0447. ○△× 24.2회.산기

다음 보기는 도스(DoS) 공격 중 하나인 'Ping of Death' 공격에 사용한 명령어이다. 명령어의 의미를 설명하시오.

보기

ping -n 100 -l(소문자 L) 65500 172.16.0.3

정답 및 해설

운영체제별 ping 명령어 옵션을 살펴보면 다음과 같다.

1) 윈도우 ping 명령어 옵션
- -n : 패킷 전송 횟수 설정(default 4회)
- -l(소문자 L) : 페이로드(데이터) 크기(byte) 설정(default 32byte)
- (예) ping -n 5 -l 128 www.algisa.com

2) 유닉스/리눅스 ping 명령어 옵션
- -c : 패킷 전송 횟수 설정(default 무한)
- -s : 페이로드(데이터) 크기(byte) 설정(default 56byte)
- (예) ping -c 5 -s 128 www.algisa.com

대상 호스트(IP : 172.16.0.3)에 페이로드의 크기가 65,500byte인(-l 65500) ICMP Echo Request 메시지를 100회(-n 100) 전송하여 매우 큰 페이로드에 의한 다수 IP 단편이 대상 호스트에 전달되도록 하는 명령이다. 대상 호스트는 다수 IP 단편의 재조합에 따른 부하가 발생하게 된다.

0448. ○ △ × 17.2회.기사

다음은 서비스 거부(DoS) 공격이 발생한 패킷 덤프 자료이다. 각각의 질문에 답하시오.

Filter: icmp.type == 8 Expression.. Clear Apply Save

No.	Time	Source	Destination	Protocol	Info
4	13.786691000	10.10.10.20	192.168.56.255	ICMP	Echo (ping) request id=0x530b, seq=0/0, ttl=64
8	14.790025000	10.10.10.20	192.168.56.255	ICMP	Echo (ping) request id=0x530b, seq=256/1, ttl=64
12	15.791904000	10.10.10.20	192.168.56.255	ICMP	Echo (ping) request id=0x530b, seq=512/2, ttl=64
16	16.793138000	10.10.10.20	192.168.56.255	ICMP	Echo (ping) request id=0x530b, seq=768/3, ttl=64
20	17.794432000	10.10.10.20	192.168.56.255	ICMP	Echo (ping) request id=0x530b, seq=1024/4, ttl=64
26	18.795652000	10.10.10.20	192.168.56.255	ICMP	Echo (ping) request id=0x530b, seq=1280/5, ttl=64
34	24.878159000	10.10.10.20	192.168.56.255	ICMP	Echo (ping) request id=0x530b, seq=1536/6, ttl=64
38	25.879260000	10.10.10.20	192.168.56.255	ICMP	Echo (ping) request id=0x530b, seq=1792/7, ttl=64
42	26.879876000	10.10.10.20	192.168.56.255	ICMP	Echo (ping) request id=0x530b, seq=2048/8, ttl=64
46	27.882197000	10.10.10.20	192.168.56.255	ICMP	Echo (ping) request id=0x530b, seq=2304/9, ttl=64
50	28.883072000	10.10.10.20	192.168.56.255	ICMP	Echo (ping) request id=0x530b, seq=2560/10, ttl=64
54	29.883873000	10.10.10.20	192.168.56.255	ICMP	Echo (ping) request id=0x530b, seq=2816/11, ttl=64
58	30.885896000	10.10.10.20	192.168.56.255	ICMP	Echo (ping) request id=0x530b, seq=3072/12, ttl=64
62	31.893273000	10.10.10.20	192.168.56.255	ICMP	Echo (ping) request id=0x530b, seq=3328/13, ttl=64
66	32.895428000	10.10.10.20	192.168.56.255	ICMP	Echo (ping) request id=0x530b, seq=3584/14, ttl=64
70	33.897731000	10.10.10.20	192.168.56.255	ICMP	Echo (ping) request id=0x530b, seq=3840/15, ttl=64
76	34.899642000	10.10.10.20	192.168.56.255	ICMP	Echo (ping) request id=0x530b, seq=4096/16, ttl=64
80	35.900696000	10.10.10.20	192.168.56.255	ICMP	Echo (ping) request id=0x530b, seq=4352/17, ttl=64
85	36.901650000	10.10.10.20	192.168.56.255	ICMP	Echo (ping) request id=0x530b, seq=4608/18, ttl=64
91	37.902460000	10.10.10.20	192.168.56.255	ICMP	Echo (ping) request id=0x530b, seq=4864/19, ttl=64

(1) 공격 명칭은 무엇인가?

(2) 공격 원리를 설명하시오.

(3) 방화벽이나 IDS/IPS 없이 대응하는 방법을 설명하시오.

정답 및 해설

패킷 덤프에서 목적지 IP가 브로드캐스트 주소(192.168.56.255)로 설정되어 있으며, 동일한 출발지 IP(10.10.10.20)에서 다수의 ICMP Echo Request 패킷이 반복적으로 전송되고 있는 점을 볼 때, 이는 출발지 IP를 위조하여 브로드캐스트로 전송하는 스머프(Smurf) 공격의 전형적인 패턴으로 판단할 수 있다.

1) 스머프(Smurf) 공격

2) 출발지 IP를 희생자(Target) IP로 위조(IP 스푸핑)한 후 증폭(반사) 네트워크의 다이렉티드 브로드캐스트(Directed Broadcast) 주소로 ICMP Echo Request 패킷을 전송함으로써, 해당 네트워크의 모든 호스트가 ICMP Echo Reply 패킷을 희생자에게 보내도록 만들어 네트워크 대역폭을 소진시키는 서비스 거부 공격이다.

3) 대응 방법은 다음과 같다.

- 증폭(반사) 네트워크로 악용되는 것을 방지하기 위해, 외부에서 유입되는 Directed Broadcast 패킷을 라우터(네트워크 장비)에서 차단한다.
- 시스템이 증폭(반사) 역할을 하지 않도록, Directed Broadcast로 수신되는 ICMP Echo Request 패킷에 대해 응답하지 않도록 설정한다.

0449. ○ △ × 20.1회.산기 21.1회.산기

다음은 특정 공격이 발생한 상황에서 네트워크 패킷을 캡처한 결과이다. 각 질문에 답하시오.

No.	Time	Source	Destination	Protocol	Length	Info
4	13.786691	192.168.57.20	192.168.56.255	ICMP	60	Echo (ping) request id=0x0a0b,
8	14.790025	192.168.57.20	192.168.56.255	ICMP	60	Echo (ping) request id=0x0a0b,
12	15.791904	192.168.57.20	192.168.56.255	ICMP	60	Echo (ping) request id=0x0a0b,
16	16.793138	192.168.57.20	192.168.56.255	ICMP	60	Echo (ping) request id=0x0a0b,
21	165.244995986	192.168.56.100	192.168.57.20	ICMP	60	Echo (ping) reply id=0x0a0b,
22	165.245058933	192.168.56.40	192.168.57.20	ICMP	60	Echo (ping) reply id=0x0a0b,
23	166.245491645	192.168.56.50	192.168.57.20	ICMP	60	Echo (ping) reply id=0x0a0b,
24	166.245589809	192.168.56.100	192.168.57.20	ICMP	60	Echo (ping) reply id=0x0a0b,
25	166.245629815	192.168.56.40	192.168.57.20	ICMP	60	Echo (ping) reply id=0x0a0b,
26	167.249774803	192.168.56.50	192.168.57.20	ICMP	60	Echo (ping) reply id=0x0a0b,
27	167.249828651	192.168.56.100	192.168.57.20	ICMP	60	Echo (ping) reply id=0x0a0b,
28	167.250401163	192.168.56.40	192.168.57.20	ICMP	60	Echo (ping) reply id=0x0a0b,
29	168.254239034	192.168.56.50	192.168.57.20	ICMP	60	Echo (ping) reply id=0x0a0b,
30	168.254434010	192.168.56.100	192.168.57.20	ICMP	60	Echo (ping) reply id=0x0a0b,
31	168.254447506	192.168.56.40	192.168.57.20	ICMP	60	Echo (ping) reply id=0x0a0b,
32	169.257662339	192.168.56.50	192.168.57.20	ICMP	60	Echo (ping) reply id=0x0a0b,

1) 위 캡처 화면을 보았을 때 어떤 공격으로 판단되는가?

2) 1)의 공격 원리를 캡처한 내용의 각 항목을 이용해서 설명하시오.

3) 라우터를 이용하여 위 공격에 대응하는 방안을 서술하시오.

정답 및 해설

1) 스머프(Smurf) 공격

2) 캡처한 패킷을 살펴보면, 공격자는 출발지 IP를 희생자 IP(192.168.57.20)로 위조한 후, 목적지 IP를 증폭 네트워크의 브로드캐스트 주소(192.168.56.255)로 설정하여 ICMP Echo Request 패킷을 전송하고 있다. 그 결과 증폭 네트워크에 속한 다수의 호스트(192.168.56.X)로부터 ICMP Echo Reply 패킷이 모두 희생자(192.168.57.20)에게 전달되고 있다.

3) 증폭(반사) 네트워크로 악용되는 것을 방지하기 위해, 외부에서 유입되는 Directed Broadcast 패킷을 라우터에서 차단하도록 설정한다.

- 시스코(Cisco) 라우터 설정 예 : Router(config-if)# no ip directed-broadcast

0450. ○△× 17.1회.기사

다음은 특정 서버(IP: 172.30.1.100)로 유입되는 트래픽을 패킷 분석용 프로그램(Wireshark)을 이용하여 캡처한 결과이다. 각 질문에 답하시오.

No.	Time	Source	Destination	Proto	Info
10	4.737	197.126.68.138	172.30.1.100	TCP	2330 → 443 [SYN] Seq=1791992058
11	4.737	172.30.1.100	197.126.68.138	TCP	443 → 2330 [SYN, ACK] Seq=245333947 Ack=1791992059
12	4.841	33.209.230.21	172.30.1.100	TCP	2331 → 443 [SYN] Seq=2125693144
13	4.841	172.30.1.100	33.209.230.21	TCP	443 → 2331 [SYN, ACK] Seq=252291533 Ack=2125693145
14	4.952	105.99.192.92	172.30.1.100	TCP	2332 → 443 [SYN] Seq=1165955683
15	4.952	172.30.1.100	105.99.192.92	TCP	443 → 2332 [SYN, ACK] Seq=251441596 Ack=1165955684
16	5.058	206.92.2.134	172.30.1.100	TCP	2333 → 443 [SYN] Seq=325172159
17	5.058	172.30.1.100	206.92.2.134	TCP	443 → 2333 [SYN, ACK] Seq=250764414 Ack=325172160
18	5.160	14.26.131.209	172.30.1.100	TCP	2334 → 443 [SYN] Seq=1424285422
19	5.160	172.30.1.100	14.26.131.209	TCP	443 → 2334 [SYN, ACK] Seq=259269374 Ack=1424285423
20	5.260	196.178.18.30	172.30.1.100	TCP	2335 → 443 [SYN] Seq=2007668141
21	5.260	172.30.1.100	196.178.18.30	TCP	443 → 2335 [SYN, ACK] Seq=262241845 Ack=2007668142
22	5.368	126.78.92.161	172.30.1.100	TCP	2336 → 443 [SYN] Seq=1869272795
23	5.368	172.30.1.100	126.78.92.161	TCP	443 → 2336 [SYN, ACK] Seq=256502984 Ack=1869272796
24	5.476	68.30.230.127	172.30.1.100	TCP	2337 → 443 [SYN] Seq=1203097608
25	5.476	172.30.1.100	68.30.230.127	TCP	443 → 2337 [SYN, ACK] Seq=252658736 Ack=1203097609
26	5.584	100.196.103.132	172.30.1.100	TCP	2338 → 443 [SYN] Seq=842717264
27	5.584	172.30.1.100	100.196.103.132	TCP	443 → 2338 [SYN, ACK] Seq=258833789 Ack=842717265
28	5.691	83.231.242.80	172.30.1.100	TCP	2339 → 443 [SYN] Seq=1699422948
29	5.691	172.30.1.100	83.231.242.80	TCP	443 → 2339 [SYN, ACK] Seq=253143358 Ack=1699422949

1) 공격의 이름은 무엇인가?

2) 공격이 지속해서 이루어진다면 특정 서버는 어떤 상황이 발생할 수 있는가?

3) 수집한 패킷과 동일한 목적지 포트를 갖는 유사 형태의 패킷이 1초당 10개를 초과할 때 이를 차단하고자 한다. 다음 iptables 명령어를 완성하시오.

```
# iptables -A INPUT -p tcp --syn ( A ) -m limit ( B ) ( C ) ACCEPT
# iptables -A INPUT -p tcp --syn ( A ) -j DROP
```

정답 및 해설

1) TCP SYN Flooding 공격

- 다수의 출발지 IP에서 서버(172.30.1.100)의 443번 TCP 포트로 SYN 요청이 집중적으로 발생하고 있으며, 서버의 SYN/ACK에 대한 ACK 응답이 없는 것으로 볼 때, 출발지 IP 주소를 위조한 TCP SYN Flooding 공격이 발생한 것으로 판단할 수 있다.

2) 발생 가능한 상황

- 출발지 IP 주소가 위조된 상태에서는 서버의 SYN/ACK에 대한 ACK 응답이 도착하지 않으므로, 서버는 다수의 Half Open 연결 상태를 일정 시간 유지하게 되며, 결국 TCP 연결 자원(Backlog Queue)이 모두 소진된다. 이로 인해 정상 사용자의 TCP 연결 요청을 더 이상 처리할 수 없게 되는 서비스 거부(DoS) 상태가 발생한다.

3) (A) --dport 443 (B) --limit 10/s(또는 10/second) (C) -j

1) iptables -A INPUT -p tcp --syn --dport 443 -m limit --limit 10/s -j ACCEPT
2) iptables -A INPUT -p tcp --syn --dport 443 -j DROP

1) 호스트의 HTTPS 서비스(443/tcp)에 대해 초당 10개의 SYN 요청까지만 허용한다.(빈도수 초과 시 이 규칙은 일치하지 않는 것으로 처리되어 다음 규칙으로 진행)
- **-p tcp --syn --dport 443 : 443번 목적지 포트(HTTPS)의 TCP syn 패킷**
- **-m limit : 특정 규칙의 일치 빈도수를 제한하는 limit 모듈 사용**
- **--limit 10/s : 초당 10번으로 제한(분당: /m, 시간당: /h 사용 가능)**

2) 1)의 빈도수 제한 규칙(초당 10개)을 초과한 SYN 요청을 차단한다.

0451. ○△× 14.1회.기사

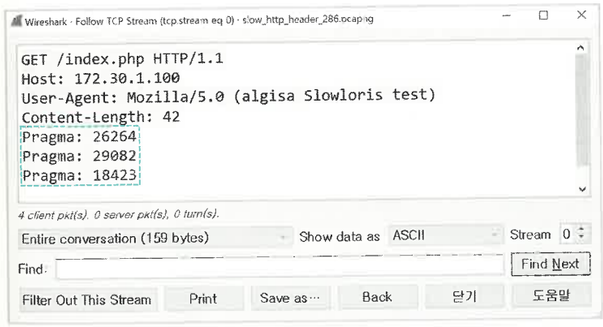
다음은 HTTP 웹 서버에 로그인이 안 된다는 연락을 받고 보안 관제요원이 HTTP 관련 네트워크 패킷을 캡처한 내용이다. 이 패킷은 동일한 출발지 IP로부터 지속해서 발생하고 있었으며 네트워크 관리 도구로 모니터링한 결과 많은 양의 트래픽을 짧은 시간에 전송하지는 않았다.

1) 어떠한 공격이며, 2) 무슨 문제점이 있는지 서술하시오.

No.	Time	Source	Destination	Prot	Info
1	0.000	10.10.1.210	172.30.1.100	TCP	52053 → 80 [SYN] Seq=70879599
2	0.000	172.30.1.100	10.10.1.210	TCP	80 → 52053 [SYN, ACK] Seq=2721217028 Ack=70879600
3	0.000	10.10.1.210	172.30.1.100	TCP	52053 → 80 [ACK] Seq=70879600 Ack=2721217029
4	0.000	10.10.1.210	172.30.1.100	TCP	52053 → 80 [PSH, ACK] Seq=70879600 Ack=2721217029
5	0.000	172.30.1.100	10.10.1.210	TCP	80 → 52053 [ACK] Seq=2721217029 Ack=70879714
6	10.020	10.10.1.210	172.30.1.100	TCP	52053 → 80 [PSH, ACK] Seq=70879714 Ack=2721217029
7	10.020	172.30.1.100	10.10.1.210	TCP	80 → 52053 [ACK] Seq=2721217029 Ack=70879729
8	20.041	10.10.1.210	172.30.1.100	TCP	52053 → 80 [PSH, ACK] Seq=70879729 Ack=2721217029
9	20.041	172.30.1.100	10.10.1.210	TCP	80 → 52053 [ACK] Seq=2721217029 Ack=70879744
10	30.063	10.10.1.210	172.30.1.100	TCP	GET /index.php HTTP/1.1
11	30.063	172.30.1.100	10.10.1.210	TCP	80 → 52053 [ACK] Seq=2721217029 Ack=70879759

```
> Frame 6: 69 bytes on wire (552 bits), 69 bytes captured (552 bits)
> Ethernet II, Src: 00:0c:29:6e:24:25, Dst: 00:0c:29:71:ab:96
> Internet Protocol Version 4, Src: 10.10.1.210, Dst: 172.30.1.100
> Transmission Control Protocol, Src Port: 52053, Dst Port: 80, Seq: 70879714, Ack: 2721217029, Len:

0000  00 0c 29 71 ab 96 00 0c  29 6e 24 25 08 00 45 00   ··)q····)n$%··E·
0010  00 37 5f 9a 40 00 7f 06  e2 c8 0a 0a 01 d2 ac 1e   ·7_·@···· ·····
0020  01 64 cb 55 00 50 04 39  89 e2 a2 32 7a 05 50 18   ·d·U·P·9 ···2z·P·
0030  fa f0 89 a0 00 00 50 72  61 67 6d 61 3a 20 32 36   ····· Pr agma: 26
0040  32 36 34 0d 0a                                     264··
```



정답 및 해설

문제의 지문과 제시된 패킷 캡처 내용을 통해 다음과 같은 사실을 단계적으로 유추할 수 있다.

- 웹 서버에 로그인이 되지 않는 상황으로 보아, 정상적인 서비스 제공이 어려운 서비스 거부(DoS) 상태가 발생한 것으로 판단할 수 있다.
- HTTP 관련 패킷을 캡처한 결과이며, 네트워크 관리 도구로 확인했을 때 짧은 시간에 대량의 트래픽이 발생하지 않은 점을 통해 저대역폭 기반의 Slow 계열 서비스 거부 공격 가능성을 유추할 수 있다.
- 캡처된 HTTP GET 요청에서 요청 헤더의 끝을 의미하는 개행 문자(CRLF, 0x0d0a)가 연속으로 두 번 전송되지 않고, 의미 없는 헤더(Pragma)가 지속적으로 전송되고 있으므로, 요청 헤더를 조작하여 연결을 장시간 유지하는 Slow HTTP Header 공격으로 판단할 수 있다.

1) Slow HTTP Header 공격(Slowloris 공격)

2) Slow HTTP Header 공격은 다수의 HTTP 요청을 전송하면서 요청 헤더의 끝을 의미하는 개행 문자(CRLF) 연속 2번을 보내지 않고, 의미 없는 헤더(예: Pragma)만을 매우 느린 속도로 지속적으로 전송하여 웹 서버와의 연결을 장시간 유지시키는 서비스 거부(DoS) 공격이다. 이로 인해 웹 서버의 동시 연결 자원이 고갈되어 정상 사용자의 로그인과 같은 서비스 요청을 처리할 수 없게 되는 문제가 발생한다.

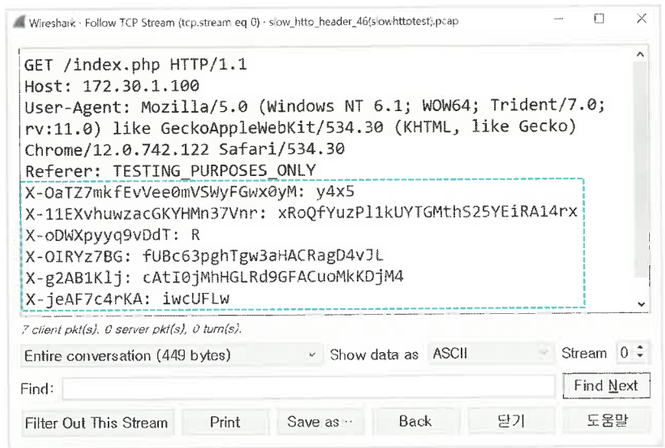
0452. ○△× 15,2회,기사

알기사 네트워크 관리자는 웹 사이트가 느려지고 있다는 연락을 받고 네트워크 트래픽을 모니터링하던 중 아래와 같은 이상 징후를 발견했다. 1) 이 공격의 명칭을 제시하고, 2) 공격 방법을 설명하시오. 그리고 3) 이런 유형의 공격으로 웹 서비스가 느려지는 이유는 무엇이며 4) 대응 방안은 무엇인지 설명하시오.

No.	Time	Source	Destination	Prot	Info
6	9.082	10.10.1.200	172.30.1.100	TCP	34858 → 80 [PSH, ACK] Seq=232 Ack=1
7	9.082	172.30.1.100	10.10.1.200	TCP	80 → 34858 [ACK] Seq=1 Ack=268
8	19.342	10.10.1.200	172.30.1.100	TCP	34858 → 80 [PSH, ACK] Seq=268 Ack=1
9	19.342	172.30.1.100	10.10.1.200	TCP	80 → 34858 [ACK] Seq=1 Ack=327
10	29.446	10.10.1.200	172.30.1.100	TCP	34858 → 80 [PSH, ACK] Seq=327 Ack=1
11	29.446	172.30.1.100	10.10.1.200	TCP	80 → 34858 [ACK] Seq=1 Ack=347
12	39.565	10.10.1.200	172.30.1.100	TCP	34858 → 80 [PSH, ACK] Seq=347 Ack=1
13	39.565	172.30.1.100	10.10.1.200	TCP	80 → 34858 [ACK] Seq=1 Ack=386
14	49.594	10.10.1.200	172.30.1.100	TCP	34858 → 80 [PSH, ACK] Seq=386 Ack=1
15	49.594	172.30.1.100	10.10.1.200	TCP	80 → 34858 [ACK] Seq=1 Ack=427
16	59.621	10.10.1.200	172.30.1.100	TCP	GET /index.php HTTP/1.1
17	59.621	172.30.1.100	10.10.1.200	TCP	80 → 34858 [ACK] Seq=1 Ack=450

```
> Frame 16: 89 bytes on wire (712 bits), 89 bytes captured (712 bits)
> Ethernet II, Src: 00:0c:29:6e:24:25, Dst: 00:0c:29:71:ab:96
> Internet Protocol Version 4, Src: 10.10.1.200, Dst: 172.30.1.100
> Transmission Control Protocol, Src Port: 34858, Dst Port: 80, Seq: 427, Ack: 1, Len: 23

0000  00 0c 29 71 ab 96 00 0c  29 6e 24 25 08 00 45 00   ··)q····  )n$%··E·
0010  00 4b 38 c4 40 00 3f 06  49 95 0a 0a 01 c8 ac 1e   ·K8·@·?·  I·····
0020  01 64 88 2a 00 50 f0 57  ec 8a 5b 5e 95 33 80 18   ·d·*·P·W  ··[^·3··
0030  01 f6 b8 b9 00 00 01 01  08 0a fc 18 99 5e 0e 7f   ······· ·····^··
0040  7f 7e 58 2d 6a 65 41 46  37 63 34 72 4b 41 3a 20   ·~X-jeAF 7c4rKA: 
0050  69 77 63 55 46 4c 77 0d  0a                        iwcUFLw··
```



정답 및 해설

1) Slow HTTP Header 공격(Slowloris 공격)

2) Slow HTTP Header 공격은 다수의 HTTP 요청을 전송하면서 요청 헤더의 끝을 의미하는 개행 문자(CRLF) 연속 2번을 보내지 않고, 의미 없는 헤더(예: X-jeAF7c4rKA)만을 매우 느린 속도로 지속적으로 전송하여 웹 서버와의 연결을 장시간 유지시키는 서비스 거부(DoS) 공격이다.

3) 웹 서버는 클라이언트로부터 HTTP 요청 메시지가 수신되면 요청 헤더를 모두 수신한 후 이를 분석하여 이후 요청 메시지 바디의 처리 방식을 결정한다. 공격자는 이러한 동작 원리를 악용하여 요청 헤더의 끝을 전송하지 않고 의미 없는 헤더만 매우 느린 속도로 지속적으로 전송하면 웹 서버는 요청 헤더 수신이 완료될 때까지 연결을 유지한 채 대기하게 되며, 이 상태의 연결이 다수 발생하면 웹 서버의 동시 연결 자원이 소진되어 사용자의 서비스 요청 처리 지연(웹 서비스가 느려짐)이 발생한다.

4) 대응 방안

- (동시 연결 수에 대한 임계치 설정을 통한 차단) 네트워크 보안장비(방화벽, IDS/IPS 등)에 출발지 IP별 동시 연결 수에 대한 임계치를 설정하고, 이를 초과하는 경우 비정상 트래픽으로 판단하여 해당 출발지 IP를 차단하도록 정책을 적용한다.
- (연결 타임아웃 설정을 통한 차단) 클라이언트와 웹 서버 간에 아무런 데이터 송수신 없이 연결을 유지할 수 있는 시간에 대해 연결 타임아웃(Connection Timeout)을 설정하고, 이를 초과할 경우 해당 TCP 연결을 종료한다.
- (읽기 타임아웃 설정을 통한 차단) 웹 서버가 클라이언트의 요청 헤더를 모두 수신할 때까지 허용되는 시간에 대해 읽기 타임아웃(Read Timeout)을 설정하고, 이를 초과할 경우 해당 연결을 종료한다.

0453. ○△× 20.1회.기사

알기사 웹 서비스 관리자는 다수의 고객으로부터 서비스 접속이 지연된다는 연락을 받고, 이를 확인하기 위해 웹 서버로 유입되는 HTTP 트래픽을 패킷 분석용 프로그램(Wireshark)을 이용하여 분석한 결과 아래 캡처한 결과를 확인할 수 있었다. 각각의 질문에 답하시오.

〈캡처1〉

No.	Time	Source	Destination	Prot	Info
1	0.000	10.10.1.210	172.30.1.100	TCP	51248 → 80 [SYN] Seq=980891321
2	0.000	172.30.1.100	10.10.1.210	TCP	80 → 51248 [SYN, ACK] Seq=3538254515 Ack=980891322
3	0.000	10.10.1.210	172.30.1.100	TCP	51248 → 80 [ACK] Seq=980891322 Ack=3538254516
4	0.000	10.10.1.210	172.30.1.100	TCP	51248 → 80 [PSH, ACK] Seq=980891322 Ack=3538254516
5	0.000	172.30.1.100	10.10.1.210	TCP	80 → 51248 [ACK] Seq=3538254516 Ack=980891520
6	10.015	10.10.1.210	172.30.1.100	TCP	51248 → 80 [PSH, ACK] Seq=980891520 Ack=3538254516
7	10.015	172.30.1.100	10.10.1.210	TCP	80 → 51248 [ACK] Seq=3538254516 Ack=980891521
8	20.029	10.10.1.210	172.30.1.100	TCP	51248 → 80 [PSH, ACK] Seq=980891521 Ack=3538254516
9	20.029	172.30.1.100	10.10.1.210	TCP	80 → 51248 [ACK] Seq=3538254516 Ack=980891522
10	30.044	10.10.1.210	172.30.1.100	TCP	51248 → 80 [PSH, ACK] Seq=980891522 Ack=3538254516
11	30.044	172.30.1.100	10.10.1.210	TCP	80 → 51248 [ACK] Seq=3538254516 Ack=980891523
12	40.059	10.10.1.210	172.30.1.100	TCP	51248 → 80 [PSH, ACK] Seq=980891523 Ack=3538254516
13	40.059	172.30.1.100	10.10.1.210	TCP	80 → 51248 [ACK] Seq=3538254516 Ack=980891524

```
> Frame 4: 252 bytes on wire (2016 bits), 252 bytes captured (2016 bits)
> Ethernet II, Src: 00:0c:29:6e:24:25, Dst: 00:0c:29:71:ab:96
> Internet Protocol Version 4, Src: 10.10.1.210, Dst: 172.30.1.100
> Transmission Control Protocol, Src Port: 51248, Dst Port: 80, Seq: 980891322, Ack: 3538254516, Len:

0000  00 0c 29 71 ab 96 00 0c  29 6e 24 25 08 00 45 00   ··)q····)n$%··E·
0010  00 ee 48 75 40 00 7f 06  f9 36 0a 0a 01 d2 ac 1e   ··Hu@···· 6····
0020  01 64 c8 30 00 50 3a 77  36 ba d2 e5 7a b4 50 18   ·d·0·P:w 6···z·P·
0030  01 00 57 dc 00 00 50 4f  53 54 20 2f 62 6f 61 72   ··W···PO ST /boar
0040  64 5f 77 72 69 74 65 2e  70 68 70 20 48 54 54 50   d_write. php HTTP
0050  2f 31 2e 31 0d 0a 48 6f  73 74 3a 20 31 37 32 2e   /1.1··Ho st: 172.
0060  33 30 2e 31 2e 31 30 30  0d 0a 55 73 65 72 2d 41   30.1.100·· User-A
0070  67 65 6e 74 3a 20 4d 6f  7a 69 6c 6c 61 2f 35 2e   gent: Mo zilla/5.
0080  30 20 28 61 6c 67 69 73  61 20 52 55 44 59 20 74   0 (algis a RUDY t
0090  65 73 74 29 0d 0a 43 6f  6e 6e 65 63 74 69 6f 6e   est)·· Co nnection
00a0  3a 20 6b 65 65 70 2d 61  6c 69 76 65 0d 0a 43 6f   : keep-a live·· Co
00b0  6e 74 65 6e 74 2d 4c 65  6e 67 74 68 3a 20 31 30   ntent-Le ngth: 10
00c0  30 30 30 30 30 0d 0a 43  6f 6e 74 65 6e 74 2d 54   00000·· C ontent-T
00d0  79 70 65 3a 20 61 70 70  6c 69 63 61 74 69 6f 6e   ype: app lication
00e0  2f 78 2d 77 77 77 2d 66  6f 72 6d 2d 75 72 6c 65   /x-www-f orm-urle
00f0  6e 63 6f 64 65 64 0d 0a  0d 0a 41 3d               ncoded···· A=
```

〈캡처2〉

No.	Time	Source	Destination	Prot	Info
1	0.000	10.10.1.210	172.30.1.100	TCP	51248 → 80 [SYN] Seq=980891321
2	0.000	172.30.1.100	10.10.1.210	TCP	80 → 51248 [SYN, ACK] Seq=3538254515 Ack=980891322
3	0.000	10.10.1.210	172.30.1.100	TCP	51248 → 80 [ACK] Seq=980891322 Ack=3538254516
4	0.000	10.10.1.210	172.30.1.100	TCP	51248 → 80 [PSH, ACK] Seq=980891322 Ack=3538254516
5	0.000	172.30.1.100	10.10.1.210	TCP	80 → 51248 [ACK] Seq=3538254516 Ack=980891520
6	10.015	10.10.1.210	172.30.1.100	TCP	51248 → 80 [PSH, ACK] Seq=980891520 Ack=3538254516
7	10.015	172.30.1.100	10.10.1.210	TCP	80 → 51248 [ACK] Seq=3538254516 Ack=980891521
8	20.029	10.10.1.210	172.30.1.100	TCP	51248 → 80 [PSH, ACK] Seq=980891521 Ack=3538254516
9	20.029	172.30.1.100	10.10.1.210	TCP	80 → 51248 [ACK] Seq=3538254516 Ack=980891522
10	30.044	10.10.1.210	172.30.1.100	TCP	51248 → 80 [PSH, ACK] Seq=980891522 Ack=3538254516
11	30.044	172.30.1.100	10.10.1.210	TCP	80 → 51248 [ACK] Seq=3538254516 Ack=980891523
12	40.059	10.10.1.210	172.30.1.100	TCP	51248 → 80 [PSH, ACK] Seq=980891523 Ack=3538254516
13	40.059	172.30.1.100	10.10.1.210	TCP	80 → 51248 [ACK] Seq=3538254516 Ack=980891524

```
> [Timestamps]
> [SEQ/ACK analysis]
  TCP payload (1 byte)
  TCP segment data (1 byte)

0000  00 0c 29 71 ab 96 00 0c  29 6e 24 25 08 00 45 00   ··)q····)n$%··E·
0010  00 29 4c 3b 40 00 7f 06  f6 35 0a 0a 01 d2 ac 1e   ·)L;@···· 5····
0020  01 64 c8 30 00 50 3a 77  37 80 d2 e5 7a b4 50 18   ·d·0·P:w 7···z·P·
0030  01 00 2c 5b 00 00 41 00  00 00 00 00               ··,[··A·····
```


1) 어떤 공격이 발생하고 있는 것으로 판단되는가?

2) 판단의 근거를 캡처한 이미지에서 찾아 상세하게 설명하시오.

3) 공격에 대한 서버 측 대응 방안을 2가지 서술하시오.

정답 및 해설

1) Slow HTTP POST 공격(RUDY 공격)

- Slow HTTP POST 공격(RUDY 공격)은 다수의 HTTP POST 요청을 전송하면서 Content-Length 헤더 값을 실제 전송할 데이터 크기보다 매우 크게 설정한 후, 매우 작은 데이터를 천천히 지속적으로 전송하여 웹 서버와의 연결을 장시간 유지시키는 서비스 거부(DoS) 공격이다.

2) 〈캡처1〉의 4번 패킷을 보면 HTTP POST 요청 시 Content-Length 헤더에 매우 큰 값인 1,000,000바이트가 설정되어 있다. 그러나 실제로는 2바이트(A=)의 데이터만 전송되고 있으며, 약 10초 후 발생한 〈캡처2〉의 6번 패킷에서도 1바이트(A)의 데이터만 전송되고 있다. 즉, HTTP POST 요청 시 Content-Length 값을 매우 크게 설정한 뒤 실제 데이터는 매우 느린 속도로 소량씩 전송하여 웹 서버의 연결 상태를 장시간 유지시키고 있으므로 Slow HTTP POST 공격으로 판단할 수 있다.

3) 서버 측 대응 방안(선택 2)

- (동시 연결 수에 대한 임계치 설정을 통한 차단) 네트워크 보안장비(방화벽, IDS/IPS 등)에 출발지 IP별 동시 연결 수에 대한 임계치를 설정하고, 이를 초과하는 경우 비정상 트래픽으로 판단하여 해당 출발지 IP를 차단하도록 정책을 적용한다.
- (연결 타임아웃 설정을 통한 차단) 클라이언트와 웹 서버 간에 아무런 데이터 송수신 없이 연결을 유지할 수 있는 시간에 대해 연결 타임아웃(Connection Timeout)을 설정하고, 이를 초과할 경우 해당 TCP 연결을 종료한다.
- (읽기 타임아웃 설정을 통한 차단) 웹 서버가 클라이언트의 요청 메시지 바디를 모두 수신할 때까지 허용되는 시간에 대해 읽기 타임아웃(Read Timeout)을 설정하고, 이를 초과할 경우 해당 연결을 종료한다.

0454. ○△× 14.2회.산기

알기사 웹 사이트 관리자는 회사 내에서 Recursive/Cache DNS 서버를 운영하고 있다. 어느 날 A.B.C.D IP 기관으로부터 회사의 DNS 서버(SERVER_IP)가 UDP Flooding 공격에 악용되고 있다는 연락을 받았다. 회사의 DNS 서버에서 트래픽을 확인해 보니 다음과 같은 다수의 질의(Query)가 확인되었고, 이 질의에 대한 응답(Response)의 크기는 수천 바이트로 매우 큰 것으로 확인되었다. 각각의 질문에 대해 답하시오.

Tcpdump 패킷 분석

```
08:05:23.042391  IP  A.B.C.D.44506 > SERVER_IP.53:  58361+  ANY? example.com
08:05:23.184740  IP  A.B.C.D.44710 > SERVER_IP.53:  14110+  ANY? example.com
08:05:23.360371  IP  A.B.C.D.36105 > SERVER_IP.53:  13623+  ANY? example.com
08:05:23.536582  IP  A.B.C.D.58559 > SERVER_IP.53:  51996+  ANY? example.com
08:05:23.723481  IP  A.B.C.D.59252 > SERVER_IP.53:  21316+  ANY? example.com
                                   ...
```

1) 이러한 형태의 DNS를 이용한 DDoS 공격의 이름은 무엇인가?

2) 회사의 Recursive/Cache DNS 서버가 이러한 DDoS 공격에 악용되지 않도록 하기 위한 조치 방안을 2가지 이상 서술하시오.
(단, root(.)를 포함한 특정 도메인에 대한 위임 권한(Authoritative)은 가지고 있지 않으며 Recursive/Cache DNS 역할만 수행하고 있다고 가정함)

정답 및 해설

Tcpdump 패킷 분석 내용은 다음과 같다.

Tcpdump 패킷 분석

```
08:05:23.042391  IP  A.B.C.D.44506 > SERVER_IP.53:  58361+  ANY? example.com
```

트랜잭션 ID(+ : 재귀적 질의)

출발지 IP.Port > 목적지 IP.Port

질의/응답 내용 (질의유형? 질의도메인)

1) DNS 증폭 DRDoS 공격

- 문제의 지문과 패킷 분석 내용을 보면, 출발지 IP를 공격 대상 시스템의 IP(A.B.C.D)로 위조한 다수의 ANY 타입 DNS 질의가 회사의 DNS 서버로 전송되고 있으며, 그에 따른 대량의(증폭된) DNS 응답이 공격 대상 시스템으로 전달되고 있다. 따라서 이는 출발지 IP 주소를 특정 서버의 IP 주소로 위조(IP 스푸핑)하여 증폭/반사를 유도하는 DNS 증폭 DRDoS 공격으로 판단된다.

2) DNS 서버 대응 방안

- (DNS 재귀적 질의 제한) 내부 사용자 전용 Recursive/Cache DNS 서버의 경우에는 재귀적 질의를 내부 사용자로만 제한하여 외부로부터의 재귀적 질의 요청을 차단하도록 설정한다.
- (임계치 기반 차단 정책 적용) 네트워크 보안장비(방화벽, IDS/IPS 등)에 출발지 IP별 단위 시간당 DNS 질의 건수에 대한 임계치(Threshold)를 설정하거나, DNS 증폭 공격에 주로 악용되는 ANY 또는 TXT 타입 DNS 질의 건수에 대한 임계치를 설정하여 이를 초과하는 경우 비정상 트래픽으로 판단하고 해당 출발지 IP를 차단하도록 정책을 적용한다.

0455. ○△× 21.2회.기사

알기사 보안 담당자는 서버 트래픽 모니터링 중 특정 공개 서버(SERVER_IP)에서 외부의 특정 서버(A.B.C.D)로 대량의 트래픽이 발생하는 것을 발견하였다. 아래의 패킷 일부 내용을 참고하여 다음 각각의 질문에 답하시오.

No.	Time	Src IP:Port	Dst IP:Port	Prot	Len	Info
1	5:1:17.131	SERVER_IP:53	A.B.C.D:44506	DNS	1891	Standard query reponse TXT example.com ···
2	5:1:17.231	SERVER_IP:53	A.B.C.D:44710	DNS	1891	Standard query reponse TXT example.com ···
3	5:1:17.283	SERVER_IP:53	A.B.C.D:36105	DNS	1891	Standard query reponse TXT example.com ···
4	5:1:17.393	SERVER_IP:53	A.B.C.D:58559	DNS	1891	Standard query reponse TXT example.com ···
5	5:1:17.441	SERVER_IP:53	A.B.C.D:48253	DNS	1891	Standard query reponse TXT example.com ···
...						

Wireshark 패킷 분석

1) 어떤 공격이 발생하고 있는 것으로 판단되는가?

2) 판단한 근거를 설명하시오.

3) 공격 원리를 설명하시오.

4) 공격자들이 이 기법을 주로 사용하는 이유를 두 가지 서술하시오.

정답 및 해설

1) DNS 증폭 DRDoS 공격

2) 문제의 지문과 패킷 분석 내용을 보면, 공개 DNS 서버(SERVER_IP)로부터 다수의 TXT 타입 DNS 질의에 대한 대량의 증폭된 DNS 응답이 특정 서버(A.B.C.D)로 전달되고 있다. 따라서 이는 출발지 IP 주소를 특정 서버의 IP 주소로 위조한 DNS 증폭 DRDoS 공격으로 판단된다.

2) 문제의 지문과 패킷 분석 내용을 보면, 공개 DNS 서버(SERVER_IP)로부터 TXT 타입 질의에 대한 DNS 응답이 다수 발생하여 대량의(증폭된) DNS 응답 트래픽이 특정 서버(A.B.C.D)로 전달되고 있다. 따라서 이는 출발지 IP 주소를 특정 서버의 IP 주소로 위조(IP 스푸핑)하여 증폭/반사를 유도하는 DNS 증폭 DRDoS 공격으로 판단된다.

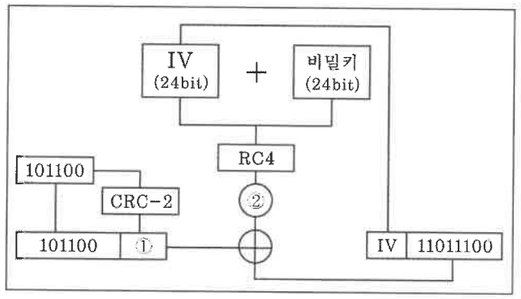
3) 출발지 IP 주소를 공격 대상 시스템의 IP 주소로 위조한 후(IP 스푸핑) 요청 대비 응답이 큰 DNS 질의 타입(ANY 타입 또는 TXT 타입)을 DNS 서버에 요청하여, 대량의 증폭된 DNS 응답이 공격 대상 시스템에 전달되도록 하는 서비스 거부 공격이다.

4) 공격자들이 이 기법을 주로 사용하는 이유

- 출발지 IP 주소를 위조하고 다수의 증폭/반사 서버를 경유하기 때문에 공격 근원지를 역추적하기 어렵다. 따라서 봇넷(좀비 PC/Device)이 노출될 가능성이 낮다.
- 요청 대비 응답이 큰 증폭 효과를 이용할 수 있어 공격 트래픽 효율이 높다.

0456. ○ △ × 13.2회.기사

다음 그림은 아래의 조건을 만족하는 무선 네트워크 보안용 WEP 개념의 프로토콜이다. 아래 (1), (2), (3)의 각 질문에 답하시오.



1) 6비트 평문 프레임 데이터 '101100'을 CRC-2로 계산한 결과값(①)을 이진 비트열로 표현하시오.

2) 암호화된 8비트 프레임 데이터('11011100')를 생성하는 데 사용된 8-bit RC4 키스트림 ②의 이진 비트열을 구하시오.

3) 다음은 첫 번째 암호문과 동일한 IV를 사용하여 암호화된 비트열이다. 이 암호문을 복호화한 원래의 6비트의 평문 메시지를 구하시오.(암호화된 프레임 데이터 =10011101)

보기

a. 초기벡터(IV)는 24bit 크기로 프레임마다 새로운 값으로 변경된다.
b. IV 값은 평문으로 네트워크상에서 전송된다.
c. 비밀키는 무선 AP에 한 번 설정하고 나면 변경되지 않는다.
d. 초기 메시지의 이진 비트열은 '101100'으로 6비트 크기이고 공격자는 이 정보를 이미 알고 있다.
e. CRC-2를 위한 코드 다항식의 비트열은 '101'이다.

정답 및 해설

1) 코드 다항식의 비트열이 '101'(1*x^2 + 0*x + 1)이므로 최고차항이 2차가 된다. 최고차항이 2차이면 6비트 평문 프레임 데이터 '101100' 뒤에 00을 붙인 후 "101" 코드 다항식과 연산을 하게 되면 그 결과는 '**10110001**'이다.

```
10110000
101        (XOR)
-----------------
  100
  101
-----------------
    100
    101
-----------------
      1
```

2) 10110001 XOR x = 11011100 이므로
x = 11011100 XOR 10110001 (XOR를 두 번 연산하면 원래의 값으로 돌아온다)
x = '**01101101**'

3) 이전 암호문과 동일한 IV를 사용하고 비밀키가 고정이므로 RC4 키스트림은 2번 문제와 동일한 '01101101'이다.
원본 6bit의 CRC값을 x라고 하면,
x XOR 01101101 = 10011101
x = 10011101 XOR 01101101
x = 11110000
x에서 CRC값 뒤 2비트를 제거하면 111100, 원래의 6비트는 '**111100**'

0457. ○ △ × 14.2회.기사

다음은 공격자가 WPA 해킹 시 사용했던 명령어를 보여주고 있다. 다음 각각의 질문에 답하시오.

보기

```
# airodump-ng -c 3 --bssid 00:18:E7:CC:C8:CF -w wpa mon0 .......................(가)
# aireplay-ng -0 1 -a 00:18:E7:CC:C8:CF -c BB:53:2E:01:03:04 mon0 ..............(나)
# aircrack-ng -w pw.lst -b [ _(A)_ ] *.cap ..................................(다)
```

1) 구문 (가)에서 bssid "00:18:E7:CC:C8:CF"는 어떠한 장비를 가리키는가?

2) 구문 (나)에서 "-c" 옵션의 의미에 관해 설명하시오.

3) 구문 (다)에서 "pw.lst"는 무엇인가?

4) 구문 (다)의 빈칸 (A)에 적절한 명령어를 기술하시오.

정답 및 해설

1) 타깃(Target) 무선 AP의 MAC 주소
2) 타깃 무선 AP에 연결된 스테이션의 MAC 주소
3) 패스워드 크래킹을 하기 위한 사전 파일(Dictionary File)
4) 타깃 무선 AP의 MAC 주소, 즉 00:18:E7:CC:C8:CF

0458. ○ △ × 13.1회.기사

다음 항목에 적절한 라우터(CISCO 라우터) 명령어를 입력하시오.

보기

1) 패스워드 암호화를 활성화
Router#configure terminal
Router(config)# [ ] [ ]
2) 패스워드를 암호화해서 저장하기 위한 설정
Router#configure terminal
Router(config)# [ ] [ ]
3) 패스워드를 평문으로 저장하기 위한 설정
Router#configure terminal
Router(config)# [ ] [ ]

정답 및 해설

1) service password-encryption
2) enable secret
3) enable password

0459. ○△× 22.2회.기사

라우터(CISCO 라우터) 설정에서 ip directed broadcast를 허용할 경우 내부 네트워크가 스머프 공격(smurf attack)을 비롯한 여러 공격에 대한 증폭과 반사 수단으로 악용될 수 있으므로 대부분의 라우터는 기본적으로 ip directed broadcast 기능이 비활성화되어있다. 이러한 환경에서 신뢰할 수 있는 네트워크 대역(192.168.1.0/24)에서 출발하는 UDP 패킷만 ip directed broadcast를 허용하고자 할 때 다음 보기의 빈칸( )에 적절한 라우터 명령어를 쓰시오.

보기

```
(config)# (    A    )
(config)# (    B    )
(config-if)# (    C    )
^z
Router#
```

정답 및 해설

기출 문제에서는 ACL 번호와 적용할 인터페이스가 명시되지 않았으므로, 예시로 extended ACL 번호 100과 인터페이스 FastEthernet0/0을 사용하여 작성함

A : access-list 100 permit udp 192.168.1.0 0.0.0.255 any

- 출발지 IP가 192.168.1.0/24(와일드카드: 0.0.0.255) 이고, 목적지가 모든 주소(any)인 UDP 패킷을 허용하는 extended ACL 100을 생성한다.
- 해당 ACL은 이후 인터페이스에서 ip directed-broadcast 명령과 함께 적용된다.

B : interface FastEthernet0/0

- 단축 명령 : int f0/0
- ACL을 적용할 인터페이스(FastEthernet0/0)의 설정 모드로 전환한다.

C : ip directed-broadcast 100

- 해당 인터페이스에서 ip directed-broadcast 기능을 활성화하고, 앞에서 만든 ACL 100을 필터링 조건으로 적용한다.
- (참고) CISCO IOS 12.0 이후 버전에서는 보안상의 이유로 ip directed-broadcast 기능이 기본적으로 비활성화되어 있으며, 필요시 기능을 활성화하려면 ip directed-broadcast 〈ACL 번호〉 형식을 사용한다.

0460. ○△×

다음 조건에 맞게 라우터를 설정하시오. (ACL은 110번 Extended Access-list를 이용)

보기

1) 192.168.1.0 대역에서 Telnet 접속을 허용하라.
2) 192.168.2.5에서 들어오는 UDP 100번~150번 포트는 허용하라.
3) 모든 웹 서비스를 허용하라. (기본 80포트를 사용한다고 가정)
4) DNS 서비스를 허용하라.
5) 그 외 모든 접근을 거부하라.
6) Serial 0 Interface에 인바운드 트래픽에 한하여 적용되게 하시오.

정답 및 해설

```
1) access-list 110 permit tcp 192.168.1.0 0.0.0.255 any eq 23
2) access-list 110 permit udp host 192.168.2.5 any range 100 150
3) access-list 110 permit tcp any any eq 80
4) access-list 110 permit tcp any any eq 53
   access-list 110 permit udp any any eq 53
5) access-list 110 deny ip any any
6) interface serial 0
   ip access-group 110 in
```

0461. ○△×

다음 조건에 맞게 라우터 보안 설정 명령어를 작성하시오.

보기

1) 사용자의 패스워드를 'dkfrltk12#$'로 설정하고 암호화된 형태로 저장한다.
2) 로깅 기능을 활성화한 후 원격 로그 서버(IP : 192.168.0.10)에 로그를 남긴다.

정답 및 해설

```
1) 패스워드 설정
   Router# conf t
   Router(config)# enable secret dkfrltk12#$
2) 로깅 활성화 및 원격 로그 서버에 로그 저장
   Router# conf t
   Router(config)# logging on
   Router(config)# logging 192.168.0.10
```